



Cyber Security, Level 3 2025/26

Student Portfolio

Student Full Name	Rozina Khatun		
Start Date	27 October 2025	End Date	
Centre	Strive Training		
Assessor/s	Paola Palazzo		
IQA	N/A		

Unit 1: Understand cyber security principles

Learning Outcome 1: Understand cyber security

1.1 Describe the concepts of cyber security

You should cover: • security • identity • confidentiality • integrity • availability • threat • vulnerability • risk • hazard.

Cybersecurity is all about securing personal and organisational information by taking security checks, identifying the right person to give access to the right information at the right time. It ensures the confidentiality, integrity, and availability of information. Cybersecurity also analyses and predicts the threats, hazards, and risks for the organisation and provides solutions to protect the business. Security refers to steps and actions that are taken to protect organisations, individuals, electronic devices (computer, mobile, printer, fax machine, etc), data, and buildings. All those steps are taken to prevent unauthorised access.

Identity is the process of recognising the right person for accessing data. So, it is a setup that ensures the right access from the right person. There are many ways of checking identity, such as username, password, fingerprints, facial recognition, voice recognition, multi-step authentication, ID card, etc.

Confidentiality is a core part of cybersecurity concepts. It prohibits unauthorised access to data. It concerns data protection and complying with the GDPR laws, which prevent unauthorised access to data. One example can be to share the right information with the right person. Another one can be data encryption.

Integrity is for maintaining the accuracy and completeness of data. Incomplete data can be problematic. It also means information should be up to date. Regular backup, saving documents while creating, taking snapshots, making two copies using two different formats, and saving 3rd copy somewhere else, separating from the original backup, saving to the cloud, or using SSDs. These are to prevent data from being lost or damaged.

Availability is to ensure that data are available to use whenever needed. It also ensures that the data are in the correct format and that the correct person has access to it. Regular maintenance, failover mechanisms, and redundancy are the methods of ensuring availability. In fact, confidentiality, availability, and integrity are the three core parts of the CIA triad to protect the information.

Threats are anything that puts the organisation, its people, and data at risk. Threats can be made intentionally or unintentionally. The examples of intentional threats are a virus, hacking the system, a cyber-attack, etc. An unintentional threat can be something that staff can do unconsciously, for example, forgetting to log out from the device that they were using. This can give access to a person who is not actually authorised for it. Therefore, data can be stolen.

Vulnerabilities are the weak spots that open the gate for the attackers to attack. One of the weak spots, for example, can be using a weak password. Because a weak password is easy to break by a hacker.

Hazards are the potential harms that the organisation or person faces. In the cybersecurity context,

hazards can be data loss, identity theft, system failure, etc.

Risk is the identification of potential loss and taking action to mitigate that loss. So, for example, what can happen if the organisational data is not saved? What can be done to mitigate this? The solutions can be saving data, copying data, and backing up data.

*Tutor Comment: Good account of the required cybersecurity concepts, with well-considered examples added. Good combination of personal research and points we covered together in class. The breach definition should say *unauthorised access rather than "authorised person has access".*

1.2 Explain the importance of cyber security.

1.3 Describe the consequences and implications of inadequate cyber security.

You should cover: • unauthorised access to distribution of or loss of: • sensitive data • personally identifiable information (PII) • protected health information (PHI) • personal information • intellectual property • industry information systems.

1.2 Importance of cybersecurity: Cybersecurity plays a vital role in this digital era. It protects the person, organisation, government, and business by protecting their information. It helps to keep the information as safe as possible. It provides the guidelines for keeping data secure, confidential, and up to date for future usage. Cybersecurity works as a shield for any organisation to make sure that its reputation is not harmed. It helps the business to comply with the GDPR so that the company does not face legal issues. For example, the National Health Service has an information governance framework in place where there is a guideline for its entire organisational information lifecycle. Staff are authorised to access to required information department-wise. Access is granted with username, password, facial recognition, fingerprints, voice recognition, and PIN. If the information is accessed unauthorised, the data can be compromised. As a result, the company will face financial loss, its reputation will be damaged, and it will lose the trust of the public. So, simply put together, cybersecurity is essential to protect the organisational digital and physical information to run the business in a healthy way by keeping its assets safe.

1.3 Consequences and implications: Sensitive data tells the attackers who we are. Personal information (name, address, etc) and Personal Identifiable Information (name, address, date of birth, email address, etc.) are sensitive information. If this information is stolen, we can face financial consequences. For example, someone can apply for a credit card with that information. If protected health information is accessed by attackers, the organisation will face a huge financial loss, and its reputation will be harmed. For example, a security breach took place in August 2022 in healthcare, according to BBC News. The hacker managed to access over 800 patients' records. Due to their weak security system, the organisation ended up with a £3m fine. Again, personal information theft can cause huge damage to us. Someone (attacker) can act like us. For example, the attacker can steal business information by acting like a member with another staff member. Therefore, the organisation will be in danger of losing money, reputation, and trust.

If any intellectual property (book, recipe, formula, design, fashion, book, logo, film, art, theory,

software, etc.) is lost or has unauthorised access, not only will it lose ownership, but it will also be affected financially.

An industry information system is another way for the organisation to manage its information. It can be a computerised system that does the specific job. Intranet and power stations are two examples of it. If, for instance, the attacker can have access to the intranet, he/she can harass the employee, steal company information, and as a result, the company will face a fine. It can be shut too.

Cybersecurity implements the right plan in practice to mitigate these types of issues and helps to run the organisation smoothly and safely.

Tutor Comment: Very good examples of the importance of cybersecurity and the consequences of not applying it; excellent coverage of data to be protected. You could emphasise that cyber security protects people as well as organisations and link each consequence directly to the impact.

Learning Outcome 2: Understand core terminology and key aspects of cyber security

2.1 Define core terminology used in cyber security

You should define: • malicious software • distributed denial of service (DDoS) • cloud • software • domain • exploit • breach • firewall • encryption • Bring Your Own Device (BYOD) • penetration testing (pen testing).

Malicious software (malware) - It is a small piece of code or a program that is designed to damage the information. These are all types of viruses, worms, spyware, ransomware, trojans, etc.

Distributed Denial of Service (DDoS) - DDoS is when a huge number of computers attack a system at the same time. It is a malicious attack on devices, servers, and systems to disrupt or crash an organisational information. If it happens, the information will be unavailable for that institution. Denial of Service can be carried out by one hacker or a group of hackers (botnet).

Cloud - It is a service platform that allows us to store our data on the internet. Here, we don't need our own storage devices (SSDs, for example). It is safer than physical storage as no one can access it physically.

Software - Software is programs and instructions that make the computer work, which perform specific functions. For example, Windows, macOS. These help us to create documents, for instance.

Domain - Domain is the unique identifier of a website, for example, gov.uk.

Exploit - It is a technique, tool, or even a piece of code that hackers use to attack a vulnerability to take advantage of.

Breach - Breach is when an authorised person has access to sensitive data. Then that data can be stolen, sold, and cause huge damage to an organisation.

Firewall - It is a protective wall that blocks unwanted websites or connections to our devices. Most

device has this by default, which stops unauthorised access and blocks DDoS attacks.

Encryption - It is a way of encoding the user input so that hackers cannot read it even if they manage to access the system.

Bring Your Own Device (BYOD) - It is a policy of allowing staff to bring their own device (computer, mobile, tablet, etc.) to work. Allowing this can be problematic, as those devices may not have an antivirus.

Penetration testing - It is also known as pen testing, which is an ethical hacking by an authorised professional to defend the organisation against any attack. This is to check if there are any vulnerabilities in the organisation. If so, it can then fix it.

Tutor Comment: Very good work on the required cybersecurity terminology and good inclusion of examples we covered in class. When explaining DDoS, you included an example from the simulation we worked on; in reality, ping is not used to rob a bank but to disrupt services.

2.2 Explain the terms good actors and bad actors.

2.3 Distinguish typical behaviours of good actors and bad actors

You should cover: • bad: ex-employee, black hat, script kiddies, hacktivist • good: white hat, certified penetration tester.

2.2 In general, good actors and bad actors are individuals with good intentions and bad intentions for an organisation, respectively.

Good actors - Good actors are trained, permitted white hats who hack the system to spot any vulnerabilities. They do this to defend the organisation.

Bad actors - Bad actors are individuals with harmful intentions for an institution. They could be black hats, ex-employees, hacktivists, etc.

2.3 Bad actors as ex-employee will act illegally and maliciously to take revenge or to sell information. Good actors on the other hand will act legally with permission to test the system to find the weak gap where attacker might attack on.

Black hats act illegally to harm the organisation. They steal information and sell it bad people for money or power. They basically abuse their knowledge for the bad intention. No doubt, good hats act like hero here to catch the bad hats and protect the institution.

Script kiddies are hackers with low knowledge and skills. They act illegally to support big hackers, for example. They do this for fun or for money.

Hacktivists are generally well-knowledge, geo-politically motivated hackers (e.g. agent works under cover). They work as hacktivist for specific reasons, for example, political or human rights motivations.

White hats do their job as they are allocated for. They are recruited for that specific action, for example, pen testing. It is part of their job. They are authorised, trained and certified to do their job. They work as a defence for the company.

Certified pen testers are with the right qualification and skills to do their job for the company. Again, they are recruited for that purpose and hold the power for that operation.

*Tutor Comment: Good account of both good and bad actors and their typical behaviours. *Good hats act like heroes (singular/plural agreement)*

2.4 Explain the motivations of good actors and bad actors

You should include bad actor: financial gain, terrorism, political motivation, reputation, disruption, respect, thrill seeking; good actor: ethical, job role, improve things, innovation, challenge of being better than a black hat.

Motivations can differ from good actors to bad actors. For bad actors, common motivations could be financial gain. They can demand ransom in exchange of stolen data. An ex-employee can harass someone who is inside the company already for some information or can sell information somewhere. Another motivation can be revenge that they were not promoted, for example.

Good hackers, on the other hand, have good intentions. They have ethical motivation; they carry out their work lawfully and have intentions to protect the organisation from the black hats.

Tutor Comment: Clear explanation of why attackers may seek money, revenge or disruption. You could expand slightly on the motivations for hacktivists (political, ideological).

2.5 Identify key sectors that are most vulnerable to a cyber-attack

You should include health • manufacturing • finance • government agencies and departments • educational institutions.

Key sectors that are most vulnerable to cyber-attack are:

Health sector - personal health information (personal information, health problems, therapies, medication, etc.), staff database, NHS numbers, hospital reference numbers, research data including new remedies and formula, customers and suppliers' data, etc.

Manufacturing - company data, staff personal data, supplier information, customer data, salaries, trades secrets, etc.

Finance - sensitive information, such as credit card, bank account numbers, company database with staff and client personal information, etc.

Government agencies and departments - Sensitive information about tax, pension, and census data. Again, staff and customer data can be targets.

Education - staff and student database, bank details, emigration information, children's data, meal suppliers' information, etc.

Tutor Comment: Good identification of sectors at risk and factors that make them vulnerable.

2.6 Compare the motivations for a cyber-attack in key sectors

Motivations for attackers in different sectors may vary. Above all, everyone is vulnerable. Attacking the health sector could be motivated by financial or geopolitical motivations. For example, stealing any new anti-virus information/formula for a specific country (ownership). Attacking manufacturing information can be for money. Again, it could be for rivalry purposes, for example. For instance, in spring 2025, in the UK, there were a few ransomware attacks. For finance, ransomware, phishing, and man-in-the-middle attacks are money-motivated attacks. Government: attackers can attack for disruption. One example is that the NotPetya attack in 2017 was thought to be a ransomware attack. However, it was the disruption to messed up the operations of the Ukrainian power supply.

Education: Revenge can work as a motivation for students who did not obtain good results. Therefore, they can do a ransomware attack.

Tutor Comment: Well thought out answer with relevant examples of motivations. Student-led revenge by ransomware in education is possible although more uncommon; more typical motivations include stealing data or disrupting services.

2.7 Consider how an actor may carry out a cyber-attack

You should state the type of attack and how it can be carried out by the actor.

A cyber attacker may attack in many ways. Phishing is one of them. The way they do this is by sending fraudulent messages to the vulnerabilities to trick them so that they click on the link. Emails, text messages, and phone calls are some of the ways that attackers attack. They try in a way that a vulnerable person or organisation believes is real. In this way, they get the credentials.

Another type of attack is a ransomware attack. An attacker can attack an individual or an organisation using the phishing technique (giving any file to download, for example). They can hack into servers or any individuals from the same network. The attacker will aim to steal and encrypt data and will demand a ransom.

The 3rd type of attack can be Denial of Service and Distributed Denial of Service. The attacks can come from malware, botnets. They cause heavy traffic, chaos, and a gap in access to a single or entire system, from one or many computers controlled by a drone. The attackers can use ping, for example, to rob a bank. They can use the command line to break the username and password. Then, they can have access to all the customers' data by using 'lm', 'cat', etc.

Further, the attackers use viruses to attack computers, mobiles, printers, machinery, and any other devices that an individual or organisation can use. It can be a piece of code pushed into any software. Or it can be SQL injection into a database. These are the access holes for the attackers. Although there are many ways for an actor to attack, the above are a few of them. The main motto of a bad actor is to steal the data to cause a huge problem. A good actor on the other hand, is to protect the data in all means.

Tutor Comment: Great examples of common attack tactics and good references to affected sectors. Very good inclusion of examples based on our class exercises: using ping to test a connection is active and then using Unix-based commands such as ls (list) and cat to gain access to information remotely.

Learning Outcome 3: Understand security by design principles

3.1 Describe the term security by design

In general terms, security by design means managing the organisational information life cycle according to a well-planned security framework. Simply, the term 'security by design' refers to deploying the security steps in every phase of the institution's assets.

From the cybersecurity point of view, there are some principles of security design, such as defence in depth, data protection, fail security, security vs usability balance, zero trust, principle of least privilege, and regular testing. When a security framework covers all of the above principles and deploys them, it is then called security by design. That security design is very cost-effective.

An example can be designing a database for a company. In the design phase, data validation could be embedded so that only the right information can be inserted. This could protect the database from SQL injection by the attackers.

Tutor Comment: Good definition of security by design and good examples of its principles.

3.2 Explore the principles of security by design

You should explore the principles set out by organisations such as the National Cyber Security Centre (NCSC), for example.

The principles of security by design set out by the National Cyber Security Centre (NCSC) are:

- Principle of Least Privilege (PoLP): giving the right amount of access to the right person, not more. For example, a sales assistant should only have access to the sales area, not to finance.
- Defence in Depth: using multi-layer security. For example, use MFA in combination with a firewall and anti-virus.
- Secure Defaults: making sure encryption is activated, and unnecessary apps are disabled from all new devices.
- Fail Securely: taking precautions before any incident or attack happens. The best practice is to keep spare machines handy in case one fails, system shuts down unexpectedly. Documents should be encrypted, backed up (with a separate copy), uninterrupted power supply should be used, for example.
- Zero Trust: no one should be trusted. Identity should be verified, authenticity should be checked before clicking, devices should be encrypted, log should be recorded.
- Secure supply chain: the company should examine the supply chain, as one company's weak point can open the door for other companies for attackers. One example of this weakness is the recent cyber-attack on JLR.
- Data protection: it is a legal requirement. Data should be encrypted, protected by a strong password, MFA, PoLP, or a combination of all.
- Usability balance: the system should not be strict enough that the user cannot use it. It should be secure and user-friendly at the same time.
- Regular testing: nothing is perfect. So, everything should be tested regularly. For example, a

penetration test should be performed every month, Apps should be tested before launching, users should be monitored, etc.

Tutor Comment: Very good, comprehensive account of several important security by design principles.

3.3 State the consequences of not considering cyber security during the design phase

You should use the NCSC guidelines to help them to state the consequences of not considering cyber security during the design phase.

The consequences of not considering cybersecurity in the design phase are limitless. Cybersecurity design and deployment is cost-effective than ending up with a huge mess and financial loss. It takes a lot of time, human resources, and money to fix problems if there is no security designed. Company data can be lost or stolen if it is not encrypted and protected. For example, not applying PoLP can enable staff to leak or misuse data that they are not supposed to have access to. The company or its individual may face legal issues (fines, penalties) if data is breached. Further damage could be to customers' trust. When consumers see any doubt about sensitive data protection, they will not turn to that company. Therefore, the company will drop the sale, lose profit, and open the door for other rivals. They may be shut too.

Deploying security in the design phase enables a company to perform its daily business activities in a more secure way.

At a national and international level, security protects the country's valuable assets from any hostile attacks. For example, keeping the nuclear information confidential can protect the country's infrastructure from becoming a target. The conclusion of deploying cybersecurity in the design phase will protect the individual, organisation, government, and the entire country both internally and externally.

Tutor Comment: Excellent coverage of consequences of not applying security by design.

3.4 Evaluate the advantages and disadvantages of security by design

You should consider an example based on your surroundings (e.g. a swipe card to enter and exit a building).

There are many advantages of security by design. The most important ones are that it is cost-effective, less time-consuming compared to the incident fixing time, protects data, and complies with data protection implications. For example, if Jaguar Land Rover had deployed security by design, it would have protected the company from losing £3bn.

The disadvantages, on the other hand, are that it needs a budget, specialised human resources to deploy and monitor, and storage, for example, to keep the records. Also, it needs expertise to fix the machinery faults or skilled professionals to train the staff.

Based on my surroundings, one example can be using a CCTV system. This gives a way to monitor what is happening around the premises, whether there is any unauthorised access to the restricted area, for example. However, monitoring needs extra human force, so will the budget. Further, storage is needed to keep the CCTV records too. Moreover, the CCTV may need a repair team in case it fails to operate. Overall, it's worth having a CCTV system to prevent any huge loss.

Another example could be using anti-virus software is better to protect the device and our information, rather than getting attacked on this and paying more as a result.

Tutor Comment: Good account of security by design pros and cons and well thought out example based on your surroundings.

Conclusion

1. Where in this unit did you use AI to support your work?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Your text appears original and you effectively combined your own ideas with points and examples from class discussions.

2. Which AI tool(s) did you use?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

3. On what date(s) did you use the AI tool(s)?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

I confirm that the evidence listed above and enclosed is my own work and was carried out under the conditions and context specified in the standards, as such no plagiarism was conducted during the completion of this portfolio.

TYPE YOUR NAME:

Rozina Khatun

Tutor Comment: Criteria met

DATE:

02/11/2025

Tutor Comment: Criteria met

Tutor feedback

COMMENTS:

Tutor Comment: In this unit you provided strong, detailed answers that show very good engagement with the topic of cyber security. You explained concepts clearly and provided many relevant examples. Your work demonstrates a growing understanding of terminology, actors, motivations and the principles of security by design. You also showed good awareness of the impact of cyberattacks on different sectors, which strengthens your responses.

You clearly explained the CIA triad (confidentiality, integrity, availability) and provided practical examples for each one; good distinction between security, identity, threats, vulnerabilities, hazards and risks. Examples such as weak passwords, backup strategies and failure to log out are relevant and realistic. You clearly explained why cyber security matters for organisations, reputation, finances and legal compliance. The use of the NHS example shows good understanding of access controls and governance. Good coverage of the consequences and implications of inadequate cyber security and very strong explanation of different types of sensitive data (PII, PHI, intellectual property); good real-world example of a healthcare breach and fines. You showed clear understanding of risks such as impersonation, fraud and reputational damage.

The core terminology definitions are accurate; your own examples help to show understanding. Clear distinction between white hats, black hats, script kiddies and hacktivists and good understanding of who acts legally and illegally. You explained motivations like revenge, profit and organisational protection effectively. Clear explanation of why attackers may seek money, revenge or disruption; good actors' motivations (ethical, authorised, lawful) are well described. Accurate identification of all major vulnerable sectors and good detail on the types of data each holds. You showed understanding that motivations change by sector (financial, political, industrial espionage, revenge). The real-world references like NotPetya improve your answer. Good explanations of attacks such as phishing, ransomware, viruses and SQL injection; you showed understanding of how attackers manipulate people as well as systems. Clear explanation that good actors test and protect systems.

good coverage of security by design and clear definition that security needs to be built into every stage of the lifecycle. Strong link to principles such as PoLP and defence in depth and good example of SQL injection prevention. Excellent coverage of NCSC principles and good inclusion of good real-world examples for each principle. Strong understanding of supply chain risks. Very thorough explanation of financial, reputational, legal and operational impacts of not considering cyber security during the design phase; good use of PoLP as an example of internal misuse. Strong awareness of national-level risks. Well-balanced evaluation of the advantages and disadvantages of security by design and relevant examples such as CCTV and anti-virus software. Your answer shows clear understanding of long-term benefits.

Equality and Diversity links: you showed an understanding of protecting personal data for all individuals, which supports fairness, equality and respectful practice. Safeguarding: you showed strong awareness of risks around PHI, children's data and identity theft. Your examples show a clear understanding of how poor security can put people at risk. British Values: you demonstrated an understanding of the Rule of Law through references to GDPR, fines and legal responsibilities and of Individual Liberty through protecting people's personal information and digital rights.

Some explanations are long and would benefit from being more concise. Try to avoid repeating the same examples (e.g. backups and financial loss appear multiple times). Some sentences are very long: breaking them up would improve clarity.

Overall, this is a thoughtful and well-developed submission: you demonstrated strong understanding across all learning outcomes and provided many relevant examples. Your effort, depth of explanation and engagement with the subject are clearly visible.

DATE:

Tutor Comment: 29/10/2025

I confirm that this student has achieved all the requirements of the units with the appropriate evidence/s enclosed. Assessment is valid, authentic, reliable, current and sufficient.

ASSESSOR FULL NAME:

Tutor Comment: Paola Palazzo

ASSESSOR SIGNATURE:

Tutor Comment: Paola

Unit 2: Threat intelligence in cyber security

Learning Outcome 1: Understand cyber threat intelligence

1.1 Identify key concepts of cyber threat intelligence.

You should be aware of the difference between the terms cyber threat and threat: • cyber threat = phishing, etc • threat = at risk.

Threat in general means risk. But in cybersecurity, it means everything that can damage the organisation and its data. The key concepts of cyber threat intelligence are manmade threats (power cut, clicking on any phishing link, leaving the device without logout, etc.) and malicious threats (malware - viruses and spyware, data breaches - loss of confidentiality, DDoS - overwhelming a system to cause disruption).

Tutor Comment: Good coverage of threats and cyber threats.

1.1 Identify key concepts of cyber threat intelligence.

You should be aware of the difference between the terms cyber threat and threat: • cyber threat = phishing, etc • threat = at risk.

1.2 Explain the following terms in relation to cyber security:

- threats
- exploits

- vulnerabilities
- risks

Threats must include: • malicious software • data breaches • Denial of Service (DoS) attacks.

Vulnerabilities must include: • flaws • features • user errors

Threats: Simply, threat in cybersecurity can include manmade or natural threats like power cut, earthquakes, fire, flood, etc. Any of these can impact on data, for example, data can be lost. In cybersecurity, manmade and malicious activities (viruses, DDoS attacks) are threats. Another type of threat can be accidental, for example, from power cut, data can be lost.

Exploits: Exploits are hackers' activities that take advantage of vulnerabilities. One of the examples can be a piece of code to push the viruses into devices to disrupt the system and gain access into it.

Vulnerabilities: These are the weak spots of the systems, software or individual users that an attacker can attack on.

Examples:

Flaws - bugs or coding error in a system, validation error of database, glitches with the network, etc.

Features - vulnerabilities in different app functions, for example, macros in Word or Excel.

User error - this is caused by users, for example, not create strong password, using same password for multiple websites, forget to logout from the device after usage, leaving devices unattended without securing it, clicking on any suspicious link, etc.

Zero-day vulnerabilities – software that are already in the market, cannot be secure sometimes. They can contain bugs or flaws from the hackers or developers. These need regular update to patch the weakness.

Risks: These are possibilities where the weaknesses are exploited and can cause data or system loss.

Tutor Comment: Good coverage of the required cybersecurity terms. Particularly good examples given for the different types of vulnerabilities. Zero-day vulnerabilities are undiscovered weaknesses that can be found by hackers (and exploited) or by the software developers (and patched).

1.3 Describe the threat intelligence lifecycle

Threat intelligence lifecycle is a pre-defined framework which is used to help analysing the threat (from outside), investigate, and find the solution to prevent the threat.

The lifecycle has six steps:

Step 1 - At this stage, staff will decide the needs and objectives of the investigation. They will make some points of why they are doing this? They can start some investigation to study more about the incident, for example, recent similar attacks can be researched.

Step 2 - Stage 2 is for information gathering. Here, cybersecurity staff will decide which sources they can use for their investigation. For example, company websites, articles, blogs, research papers, previous reports for similar attack, etc.

Step 3 - The 3rd stage is to organise the information that was gathered from the previous stage. At this

stage, any duplicate information will be eliminated, anything will be added. At the end, everything will be summarised.

Step 4 - The 4th step is analysing the information to find any patterns or useful clue for the investigation.

Step 5 - In step 5, the cybersecurity staff shares the reports and findings in the relevant format with the relevant member of the team.

Step 6 - At the last step, any feedback, adjustment from the stakeholders will be accepted and modified to get an improved version of the report.

Tutor Comment: You provided an accurate account of the threat intelligence lifecycle.

1.4 Describe how to find out about emerging attack techniques and how to recognise them

To find out about emerging techniques, there are a wide range of sources of information for the IT specialists to keep them updated. New viruses and solutions from the existing issue can help protecting the system effectively. Different organisations such as forums (reddit), @BleepingComputer, training courses, podcasts, ZDI, YouTube, conferences (InfoSec), webinars, and many more can help of recognising the emerging attacks. These sources can help to recognise the IoCs (Indicators of Compromise) which gives the signs of attacks or tells that the attacks are in progress. One example of an indicator of compromise can be a slowing down system, which can indicate a DDoS attack is in progress or maybe there is a worm.

Tutor Comment: Good range of sources of information on emerging attacks and good coverage of how to recognise Indicators of Compromise.

1.5 Consider what could be included in Open-Source Intelligence data sets

There are many resources that can be considered to investigate about the organisation or company. For example, WHOIS (<https://who.is>) is an open-source intelligence that can help cybersecurity professional to research new threats, attacks or solutions.

Another way is that the professionals can check the information by going to the gov.uk website. There they can check whether the details match or not. Further, the file can be downloaded to check if the antivirus works properly or not.

Furthermore, Virus Total can help establish if the company is legitimate or not. Here, there are some options of uploading and scanning the files to check if there are any viruses.

Tutor Comment: Good choice of sources to include in your OSINT data set.

1.6 Explain why it is important to only use reliable and valid sources of Open-Source Intelligence information.

1.7 Explain the importance of using reliable sources of information in relation to cyber security threats.

Reliable sources are of course trustworthy. Using unreliable sources can lead towards the danger. It can give wrong information to make the decision, waste time, money, labour in general. Also, it can create a real gap where the attacker can attack when cybersecurity professional remains busy. Research has shown that unreliable sources of information can lead towards bad decision. Making decision from unreliable sources can put an organisation and its people at risk. It can cause data breaches which will create legal issues. Further, using unreliable sources direct the cybersecurity professionals to create inaccurate and incomplete information. Furthermore, the professionals should use few good sources for investigation as using one source can create biasness. In summary, using good and sufficient reliable sources are very important for the cybersecurity professionals as the security of the organisation, government and country depend on them.

Tutor Comment: Very good points raised on the importance of using valid and reliable sources of information. Some of the sources you listed (YouTube, Reddit) can be very helpful, but the information they give should be verified against other more reliable threat-intelligence sources such as NCSC, CISA, NIST, MITRE or vendor threat reports (Microsoft, Kaspersky, CrowdStrike, Proofpoint)

1.8 Consider the current threat status and make possible recommendations based upon cyber threat intelligence information.

You could create a case study based on the information gathered, including recommended actions.

One recent cyberattack occurred at Jaguar Land Rover (JLR) on 31 August 2025. JLR is a British multinational automobile manufacturer. It is a huge company with around 34,000 UK employees (according to The Guardian) and 120,000 worldwide.

According to Telegram and Wikipedia sources, the attack was a collaborative attack between Scattered Spider, Lapsus\$, and ShinyHunters. They are believed to be an English-speaking cybercrime group. Cyber Monitoring Centre (CMC) classified the attack as a Category 3 event.

After the attack, the company had to pause its production until 1 October. It also advised its employees to stay at home.

The cyber correspondent estimated that the attack will cost around £1.9bn for JLR. The supply chain is in under massive disaster due to the attack. Here is not the end. All the staff will be affected, so will the British economy. This is one of the huge attacks in British history.

I would recommend taking the following steps at JLR to minimise the possibilities of this type of attack:

- implement a zero-trust policy for all staff and even for third parties
- segment networks by limiting users, separate network for supply chain
- ensure network security by partnering with government cybersecurity
- educate staff and suppliers to keep them up-to-date about cyberattack trends
- implement MFA for accessing the internal network and monitor the log
- improve the firewall security
- have cybersecurity insurance in case of any incident

Above all, I would advise JLR to stay vigilant and connected with all national and international cybersecurity networks to understand the pattern of ongoing attacks. So, they can stay safe by acting accordingly.

Tutor Comment: Good choice of a very topical and high-impact case study, the Jaguar Land Rover cyberattack, which clearly illustrates the business and national impact of ransomware and credential theft. Good inclusion of reputable information sources to support your analysis. You provided well-tailored recommendations which align with best practice. Consider including links to the sources you consulted.

1.9. Analyse relevant cyber threat intelligence information requirements for an organisation.

You must cover information on at least four different types of attack on a business to consumer (B2C) business. Types of attack could include: • phishing • ransomware • Denial of Service (DoS)/Distributed Denial of Service (DDoS) • virus.

One of the recent cyber-attacks in a popular retail company, Marks & Spencer (M & S), took place in April 2025. The company handles huge amount of business data including customers', suppliers', and staffs'.

The company experienced a ransomware attack. The data is stolen and encrypted. The attackers then demanded the ransom. It affected the entire company; the in-store payment system was affected, and online payment was shut down. Because of that attack, M & S had to lose £300 million (according to the company website) in yearly profit. Further, the company had to spend more money to pay around 200 agency workers to slow down the order processing. Its reputation, on the other hand, is damaged.

The possible attack could be a phishing attack. As the receptionist received a phone call asking credentials, this indicates that the attacker tricked the receptionist by being someone of the company.

Further, it could be a Denial of Service (DoS) or Distributed Denial of service (DDoS) attack too. A huge group could be involved as m&s is a huge company. They could be financially motivated. Surprisingly, hacktivist could have attacked too as m&s sales many products which are made up of fur, feather or leather.

Another possible attack could be viruses. As, m&s manages its business through many software and platforms, viruses might have been pushed to slow the system down and gain access to the company data.

There are many steps that m&s could have taken to protect the company. If I would be the cybersecurity staff of m&s, I would prioritise to monitor for phishing campaigns, protect all the organisational assets against ransomware, and ensure any available platform against DDoS attacks.

I would perform the following actions:

- conduct regular CTI assessments and adapt with any changes
- train all the employees
- make current awareness available for everyone in the company
- keep in touch with the customer by giving the brochure, speaking to them in store when they visit, for example
- subscribe any necessary cybersecurity product
- monitor fake websites, emails, etc.

- back up the company data by following 3-2-1 process
- partner with Cloudflare or AWS
- monitor the network traffic to notice any abnormalities
- make redundancy with failover systems
- deploy advance firewall and anti-virus
- organise for supply chain audits
- follow other OSINT sources that could help to protect the data
- watch YouTube for any helpful information
- finally, contact with the anti-fraud organisation for any further suggestions.

Tutor Comment: Your answer covers a good range of cyber threats. Excellent inclusion of a real-life example, the recent Marks & Spencer ransomware attack. The countermeasures you suggested are well researched, relevant and practical. Great examples of where OSINT sources can help prevent the risks that these attacks will be successful.

Learning outcome 2: Understand threat models

2.1 Describe a range of threat models.

You must describe a minimum of three threat models.

2.2 Explain the steps within a threat model

2.1 Threat models are a predefined approach to understanding the gaps and ways that attackers may use to attack. It helps IT professionals analyse every asset of the company to ensure there is no gap. Also, if the organisation is attacked, it has steps to follow to minimise the risk and damage.

There are many threat models nowadays. Each comes with different features. Just one framework may not be enough for an organisation. In that case, IT professionals can use a combination of different frameworks for a better understanding. Although there are many frames, I am going to briefly discuss three models, which are the STRIVE, the NIST model, and the Cyber Kill Chain.

STRIDE: The STRIDE model was developed by Microsoft, and it is a mnemonic word that consists of six letters. Among the six letters, the first one, 'S', refers to Spoofing (copying the email, file, or website to trick). The next one is 'T', and it stands for Tampering (changing the data). The 3rd one is 'R', which stands for Repudiation (denying an action), next is 'I', for Information Disclosure (unauthorised access to information or leakage). The fifth one is 'D', and it stands for Denial of Service or DoS (making the information inaccessible by disrupting the system). The final one is 'E', and it stands for Evaluation of Privilege (regular user having access to anything deeper). STRIVE is used both for internal and external purposes. It is especially good for software and system design.

NIST (National Institute of Standards and Technology) Cyber Security Framework / NIST CSF: It is more like a risk assessment framework. It examines the attack from a defensive point of view. This is a general, straightforward framework, which has five core functions. They are - identify, protect, detect,

respond, and recover. So, identifying the risk or vulnerability, taking action to protect the information, monitoring it continuously, responding to any incident to mitigate the risk, and recovering the operation after the incident are the core steps of this framework. For example, an energy company uses this framework to secure the system.

The Cyber Kill Chain: It is a very good model to act like a real attacker. Again, this model works from the attacker's point of view. It has 7 quite strong steps to analyse and prepare for the attack. Reconnaissance (information collection about the target), Weaponization (prepare the malware), Delivery (attack), Installation (malicious software installation), Command and Control/ C2 (way of communicating with the attacker), and Actions on Objectives (target complete by stealing information). The model is useful to detect where the defence could fail.

2.2 I am going to discuss the steps of STRIDE.

1. STRIDE: STRIVE is a mnemonic word with six steps, as per six letters. This model is developed by Microsoft. The steps of STRIDE are:

Spoofing: It helps to recognise if there is any imitated email or website to trick a user into gaining access. For example, a hacker can use <http://www.jfc.co.uk> instead of <https://www.kfc.co.uk>.

Tampering: This step is about checking if the data was altered or had unauthorised access. One example can be SQL injection into a company's database.

Repudiation: Repudiation is when an individual denies that he/she did not perform any malicious activity. It is easy to say that, when access is not restricted by username and password, for example.

Information Disclosure: This stage is to check any gaps in accessing the information. For example, if it is not a strong password-protected, or MFA is not enabled, hackers can easily have access, steal data, and leak it.

Denial of Service (DoS): At this stage, the professional will act like an attacker and will make a disruption by accessing into company's computers. They will then make the data inaccessible, encrypt it, and demand a ransom.

Elevation of Privilege: This step is to find out if any normal hacker can access multiple targets within the system. Or even, it can help to find out whether a finance manager can have access to the IT system, for example.

Overall, STRIDE is a very useful framework.

Tutor Comment: Good coverage of a selection of threat models and of the stages of STRIDE.

2.3 Evaluate a threat model

I am evaluating the STRIDE model, as I have discussed in my previous questions.

No single model is one hundred percent. Each one comes with different features. However, the STRIDE model is a strong model.

Advantages of this model are:

- It is easy to understand as it is quite straightforward
- It looks threats both from inside and outside
- It has a clear structure (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service,

and Evaluation of privilege)

Disadvantages of the model are:

- It is an ancient model as it does not cover the cloud services, for example
- It does not assess the impact or risk

One example is that when a company uses this model, STRIDE helps the team to consider credibility (spoofing), tampering (transaction), or SQL injection (disclosing information). However, it does not assess the priority of the response or the impact of the incident.

Tutor Comment: Well considered evaluation of STRIDE and good inclusion of a contextualised scenario.

Learning outcome 3: Understand malicious software

3.1 Identify types of malicious software

You should include: • virus • spyware • trojan • worm

There are different types of malicious software, like viruses, spyware, trojans, and worms.

Virus: It is a malicious software that tricks the user to click on the given link so that the attacker can have access. It could be via a phishing email or text.

Spyware: It is a program that collects passwords and other sensitive information when the user visits any websites, for example. It enables hackers to gather information and use it to reach the target by staying invisible.

Trojan: It is a hidden piece of code that attackers use in a game, video, link, or app. A human (IT professional) can detect this behaviour or pattern.

Worm: Worm is transferable; once inserted through an app, link, file, or other programs, it does not need any human to activate. It can pass to other devices at the same time.

Tutor Comment: Good summary of common types of malware.

3.2 Describe the effects of different types of malicious software on an infected system

The effects of different types of malicious software on an infected system may vary device to device, for example. However, the common ones, like worms, can cause a system slowdown. The impacted devices will slow down their function and can glitch. Further, many computers affected together can have a short time, which may indicate that data is compromised.

Further, viruses can switch off the antivirus or firewall of affected devices. Other impacts could be that the device will get extremely hot, glitch, and lots of pop-ups will appear.

Tutor Comment: Good summary of common effects of malware on systems. Particularly good coverage of the effects of worms.

3.3 Describe the motives for using specific malicious software attacks

Finance can be the main motivation for a Trojan attack. For spyware and worm attacks, the same motivation can play a vital role. However, it can be for further reasons, like damaging the reputation of a company. Hacktivists or competitors can act like hackers here.

Further, fame can motivate hackers in a way that they want to be famous; they want to grab attention. Again, attacker can use any form, like worms, viruses, Trojans, or spyware, depending on their budget, skills, and knowledge.

Patriotism can work as a motivation for attackers too. For example, attackers can attack using a DDoS form (quantum bot) to destroy any country's asset, nuclear power station, for example. So, it is difficult to analyse the motivation of why cyber criminals are attacking. But mostly we can say that among others, financial motivation is the root one.

Tutor Comment: Very well researched account of motivations for malware attacks.

3.4 Identify how specific malicious software attacks are made more effective due to human factors

Human error plays a vital role in making an attacker's attack more effective. Human errors can be intentional or unintentional mistakes. Greed for money, revenge, fame, or pressure can be intentional errors. However, unintentional errors are errors that made by a human unconsciously, such as forgetting to log out from a device, using weak passwords, leaving devices unattended without logout, or due to negligence, and lack of knowledge.

Any of those opens the access door for hackers or attackers. For example, clicking on a suspicious link can give access to a hacker to get the credentials (e.g. password). Hackers then can access to data, encrypt it, and demand a ransom. Other example can be responding to any button inside the game. Attackers can push the virus to a device, its system, or to its RAM. Again, this happens when a human clicks on the link.

Tutor Comment: Very good recognition of the role of human error in social engineering attacks.

Learning outcome 4: Know about social engineering

4.1 Explain the term 'social engineering'

Social engineering is a tactic to trick a human emotionally or psychologically into clicking or responding to any link, text, email, QR code, voice calls, pretending to be someone that the vulnerable person knows, etc. This is conducted by hackers to gain access to data. In this way, hackers get access to devices or their data. They then use it to demand a ransom, for example.

Another example can be scanning the QR code. Malware can be hidden behind and open the access door for hackers. So, many more attacks are effective because of social engineering.

Tutor Comment: You defined social engineering precisely and showed a strong understanding of how it exploits human behaviour.

4.2 Give examples of how Open-Source Intelligence can be used for social engineering.

Open-Source Intelligence has very useful tools and techniques that can be used for social engineering. Have I Pwned is one of the Open-Source Intelligence tools that can be used to check any domain, website, and its details of when it was registered, whether it has a valid certificate, and if it is still valid, etc. This then helps to decide if the website is safe to click on or not.

Attackers can collect data from social media (LinkedIn, Facebook, x, etc.) and use it to attack. They can then pretend to be a manager and ask for login details to any staff. In this way, they will have access to data. This can be effective for spear phishing and whaling attacks.

Using AI technology, attackers can attack as well. For example, a deepfake voice can be effective in vishing attacks.

One good example can be job seekers. People often create a network on LinkedIn. Hackers can act as employers and post a job or file to apply for a job. That link or file can contain malware. So, clicking on the link will give access to hackers.

Tutor Comment: Well thought out example of OSINT use in social engineering attacks.

4.3 Describe ways a social engineering attack could take place.

You could undertake a case study to gather information using Open-Source Intelligence and give examples of how the information could be used to carry out a social engineering attack.

Attackers can use Open-Source Intelligence tools and techniques for bad intentions. Hackers can gather necessary information via LinkedIn, TikTok, Facebook, WhatsApp, and so on. They may take a long time to build a connection with the target. When they gather enough information, they attack in many ways, for example, sending an email with malware, sending a text with a link to click on, making a voice call by pretending as a known person, and so on. One example of spear phishing is "John Podesta: 2016 DNC Email Leak via OSINT". The attackers gathered information about John Podesta, who was the campaign chairman of Hillary Clinton. They sent a fake email (Google Security alert email). The email had a link that John clicked on and entered the credentials to reset the passwords. This is how the hackers got access to 60,000 private emails. So, from the above discussion, it is clear that social engineering is a gateway for attackers to make their attack effective.

Tutor Comment: Your social engineering case study on the Hilary Clinton of 2016 email leak presents a strong use of a real-world case with very good OSINT use coverage. You devised a good scenario to illustrate how attackers can gather data and trick users. Ideally, include some details of your recommended preventive measures. You could also include links to your information sources.

Conclusion

1. Where in this unit did you use AI to support your work?

If not applicable to you, please answer "N/A"

I haven't taken any AI help. However, there is Grammarly on my computer that I could not get rid of. I sometimes paid attention to that for spelling.

Tutor Comment: You made effective use of your AI-based grammar and spell-check tool to give your work a professional finish; the content itself is clearly grounded in your own ideas and class discussions.

2. Which AI tool(s) did you use?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

3. On what date(s) did you use the AI tool(s)?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

I confirm that the evidence listed above and enclosed is my own work and was carried out under the conditions and context specified in the standards, as such no plagiarism was conducted during the completion of this portfolio.

TYPE YOUR NAME:

Rozina Khatun

Tutor Comment: Criteria met

DATE:

04/11/2025

Tutor Comment: Criteria met

Tutor feedback

COMMENTS:

Tutor Comment: In this section you produced a strong and detailed set of answers that shows good understanding of cyber threat intelligence, threat models, malware, OSINT and social engineering. You gave a wide range of examples, and you explained concepts well. You showed clear understanding of the key ideas and related them to realistic scenarios.

You explained threats, vulnerabilities, risks and exploits confidently. Your examples (power cuts, weak passwords, DDoS, SQL injection, spoofing) help show your good understanding of how attacks happen in real situations. Good explanation of the threat intelligence lifecycle: your six-step description is accurate and shows good grasp of the stages of the model. Effective use of real examples: your use of the Jaguar Land Rover and M&S attacks shows excellent awareness of current threat activity. You also made sensible recommendations, which show good application of cybersecurity theory to real organisations.

Good knowledge of malware and social engineering: you explained viruses, worms, spyware and

trojans clearly and related them to human error, which is accurate and relevant. Your discussion of phishing, vishing, deepfakes, QR scams and OSINT-based attacks shows good awareness of modern social-engineering threats.

You showed good awareness of responsible online behaviour, protecting personal data, avoiding misinformation and recognising human error risks. These points all relate to Safeguarding, Equality and Diversity (respect and fairness) and British Values such as the rule of law and individual responsibility. Some sections are rather long. Breaking paragraphs into shorter, clearer points will help your work read more smoothly.

Overall, this is a good, well-developed submission. You showed strong progress and clear understanding across all topics. Your explanations are thoughtful, detailed and supported with relevant examples.

DATE:

Tutor Comment: 05/11/2025

I confirm that this student has achieved all the requirements of the units with the appropriate evidence/s enclosed. Assessment is valid, authentic, reliable, current and sufficient.

ASSESSOR FULL NAME:

Tutor Comment: Paola Palazzo

ASSESSOR SIGNATURE:

Tutor Comment: Paola

Unit 3: Cyber security testing, vulnerabilities and controls

Learning Outcome 1: Understand common types of testing in cyber security

Unit summary: The learner will gain an understanding of common types of testing in cyber security including mitigations following testing. They will understand vulnerabilities within cyber security and the steps to be taken when a vulnerability is identified. Learners will also gain knowledge of controls within cyber security and will be able to apply a basic control.

1.1 Explain different types of cyber security testing

You must include: • penetration testing • vulnerability scan • social engineering test.

There are various types of cybersecurity testing. Some of them are penetration testing, vulnerability scan, social engineering test, Virtual Machine test, Security audits, Network testing, etc. These are part of proactive security tests.

Penetration testing (Pen testing): Pen testing is one of the necessary tests in cybersecurity. It tests the strengths of a company's security by looking for any loopholes for hackers to attack.

Pen testing is ethical testing where the professionals are equipped with the necessary knowledge and skills, and they have permission to do so. Pen tests can be done as follows:

Black box testing - the tester does not have any prior knowledge about the system and aims to check the system as an external attacker.

White box test - this test is conducted by a permitted professional who knows about the internal system. This test is to find the internal gap.

Gray box testing - this test conductor has partial knowledge of the system and conducts the test using a hybrid model.

Another way of performing a pen test is diving into two different groups. One group act as the red team (attacking), whereas the other group acts as the blue team (defender). Some of the popular software to perform the pen test are Kali Linux, Parrot OS, Metasploit, etc.

Vulnerability test: This test can be done using software to scan computers and devices to find identity issues. For example, if there is a weak password, the password is not changed for a long time, or if there are any pending updates. The software can do the tasks automatically or with a little help from a human. However, logs should be checked regularly.

Social engineering test: This test is conducted to identify weaknesses in the staff. A professional can send an email or text to staff for testing purposes. Even a device can be left for the staff to check if he/she picks that up or not. Another way is that a professional can act like a hacker and offer any USB to the staff to check if the staff is knowledgeable or not. If not, then staff should attend training. All these are to check if attackers can attack the company through the staff.

Tutor Comment: Good account of vulnerability scans, pen testing and social engineering testing. Virtual Machines are tools commonly used in testing.

1.2 Identify why cyber security testing is important

Cybersecurity testing is crucial for anyone (individual, company, government, country). It detects any weaknesses in devices, in systems, or in individuals. It is very important as it allows the testers to spot the weaknesses and take the necessary steps to prevent from attack. It saves money, time, reputation, and keeps operations smooth. Cybersecurity testing allows companies to comply with the GDPR rules and regulations. Therefore, it prevents data breaches (e.g., protecting staff data). Further, it helps to build trust sector-to-sector, government-to-public, for example, protecting the taxpayers' database builds trust between the government and the public.

Tutor Comment: Good answer showing understanding of the importance of security tests.

1.3 Compare types of cyber security testing

Each of the cybersecurity comes with different strengths, features, and purposes. So, professionals use a combination of them. With typical testing and adjustments based on the current technological era, it is hard to predict which way attackers will attack. Therefore, testing systems are continuously changing their faces too.

Vulnerability testing is good at identifying common vulnerabilities in individuals, systems, and networks. It is an automated scan, can be performed regularly to detect emerging risks. It is cost-effective and quick. However, it is limited to known vulnerabilities, and it may bypass configuration

issues or zero-day threats.

Penetration test (pen test) is good to prepare for a real-world attack. It is a combination of automation and human touch. The test can be done monthly, for example. It can identify exploitable vulnerabilities. It is timesaving compared to post-incident response time. It is customizable and provides real-world security testing. However, it needs proper skills and knowledge, resources and money.

Social engineering test is conducted in many ways (phishing, vishing, baiting, or pretexting) to test human vulnerabilities. It makes staff aware of different ways that they can be attacked. Therefore, they can stay alert. So, the tests highlight staff weaknesses and improve awareness training. However, it may raise ethical concerns. Further, it only looks at the human element, not the network, system, or other elements.

From the above discussion, it is clear that one test may not serve the purpose of the company. Therefore, it is good to use a combination.

Tutor Comment: Excellent comparison between vulnerability scans, pen testing and social engineering testing.

1.4 Consider mitigations following cyber security testing

You must include: • escalation • patching • user access control • high availability • staff training and awareness.

Mitigations are the measures taken by the cybersecurity professional after spotting the weaknesses. These can be escalation, patching, user access control, high availability, staff awareness and training, and so on.

Escalation: This measure is taken when one issue cannot be solved. IT teams are generally divided into three different levels. When issues cannot be solved at the first level, they raise a ticket and pass it to the next group by recording the issue and declaring it as unsolved. When the second team fails, then they pass it to the 3rd team with enough information on what the issue was, what has been done, and all clear information.

The next measurement is patching. It is a temporary solution that allows the IT professionals to find more permanent solutions or updates. Patching should be done as soon as possible, as the updates come with more security, for example.

User control is another measure that should be taken by IT professionals. This is giving limited access to the right person, not more. This way, other data leakage can be prevented if the person attacked is from another department, for instance.

High availability is another important measure. It ensures the system's functionality and availability even after an attack or system failure. Keeping spare machines to replace in case if there is any unexpected failure, proper backup (3-2-1) ensures data can be obtained when needed, and so on.

Staff training is to keep the staff up to date with all the necessary knowledge and skills. It is to keep them alert to what is going on around the world related to cybersecurity concerns. For example, make

them aware of phishing emails or texts, and explain the consequences that they can face.

Tutor Comment: Comprehensive coverage of key types of mitigations.

1.5 Explain why it is important to retest following any changes made

Retesting after making any changes is very important, as any new change can make the system difficult for users. So, it helps to monitor if any further adjustments are needed, or staff need further help to cope with the change. Also, it helps to keep track of the updates, for example, is the device performing as expected?

Tutor Comment: Well considered answer on the importance of retesting after changes.

1.6 Explain how the outcomes of cyber security testing can be reported.

1.7 Explain why the outcomes of cyber security testing must be reported.

1.6 The outcome of cybersecurity can be reported using vulnerability scan logs or SIEM logs. Using other means like Microsoft Word, Excel, PowerPoint, Power BI, Google Docs, or PDF, findings can be recorded as reports.

It is very essential to report the cybersecurity testing outcomes. The problems that are found in the testing phase must be communicated to resolve them. The entire reason for conducting the tests is to find the weaknesses and fix. But if these are not communicated, then they will remain hidden. Therefore, attackers will attack. Therefore, reporting the outcome will help the company to take necessary steps to prevent data, staff, and the company. Reports work as evidence in the court if anything worse happens. Also, it can be used to improve the system and business of the company. It helps to make strategic decisions. Overall, the report works as a bridge that fills the gap between the system and loopholes.

Tutor Comment: Well considered answer covering both aspects effectively. You could add details on who should receive the reports or what audiences are involved.

Learning outcome 2: Be able to reduce or remove potential cyber security vulnerabilities

2.1 Identify cyber security vulnerabilities

You should identify a range of cyber security vulnerabilities, taking into account cloud based and on-premises as well as common vulnerabilities in networks and systems.

Ranges of cybersecurity vulnerabilities include network, system, cloud, or on-premise

Network vulnerabilities: Some common network vulnerabilities occur due to unsecured protocols (plain text communication - FTP, Telnet, HTTP, lack of SSL or TLS), improper network configuration -

weak firewalls, misconfigured DNS, lack of proper segmentation, outdated network devices, etc.

System vulnerabilities: lack of regular testing / weak passwords / database not validated properly, allowing SQL injections / lack of VLANs / buffer overflows / lack of firmware update / file uploading without checking further.

Cloud vulnerabilities: this is easiest way for hackers to access. Using weak passwords, sharing access credentials, sharing files with everyone without securing them, insufficient API security, using insecure communication channels, especially with third parties, etc., creates access door for hackers.

Physical or on-premises vulnerabilities: poor access controls (not using biometric authentication, for example), running unsupported devices or software, a poor / lack of recovery plan, lack of access monitoring, power cut, etc., are the ways that the attackers can reach the vulnerabilities.

Tutor Comment: Great examples and good breakdown into system, network, cloud and physical vulnerabilities. Cloud systems can be hacked into if not protected adequately (for example, passwords used are weak) but can also be extremely secure. Lack of VLANs can be a system vulnerability if a secure connection is needed to protect data, for example when staff work from home and need access to company data.

2.2 Demonstrate the steps to be taken when a vulnerability has been identified

You must demonstrate the steps to be taken when a vulnerability has been identified. Whilst the steps will vary, you must include reference to organisational policies or procedures within the steps.

If a vulnerability is found, the following structured steps should be taken:

Step 1 - identify the weaknesses and evaluate the likelihood possibilities using the risk assessment framework.

Step 2 - record the findings and share them with the relevant IT team.

Step 3 - apply patches to fix the weaknesses temporarily.

Step 4 - apply a permanent fix.

Step 5 - follow up on the fix to check if it is working as planned and record the test.

Step 6 - keep monitoring to spot any issues and keep records of them.

Tutor Comment: You gave an accurate account of the steps to follow if a vulnerability is found.

2.3 Apply the correct response to the vulnerability

Examples of responses could be modifying a database to include data validation to protect it from SQL injections, applying a strong password policy by restricting 12-15 mixed characters, for example, restoring data from a backup, installing a verification procedure for updates or patches, and staying vigilant.

Tutor Comment: Great examples of suitable responses.

2.4 Develop an appropriate communication to mitigate future vulnerabilities

Communication documents could include an information leaflet or an email to management informing them of a vulnerability.

Dear IT Manager,

I have reviewed the logs from the vulnerability scan system carried out last night. I had identified that many of our staff members have not updated their passwords. From the system's flag, I spotted that the software is not updated. So, I have created a poster to raise staff awareness. I am emailing you the poster.

I will create a strong password policy to enforce regular password changes and automate the software updates.

The team and I will enforce the policy on the system. Thank you.

Kind Regards

Tutor Comment: You provided a clear and communicative sample email. Ideally, also provide examples of other appropriate communication channels such as leaflets or webinars.

Learning outcome 3: Understand controls in cyber security

3.1 Identify cyber security controls

Cybersecurity controls are tools and techniques that are implemented to protect information, individual, business, government, and everyone.

There are two types of controls. The first type is preventive, detective, and corrective. The 2nd type is technical, administrative, and physical.

Preventive controls: This type of control is taken beforehand to protect data. Some examples are the firewalls, document encryption, using strong passwords and Multiple Authentication, the antivirus, implementing a zero-trust principle, keeping spare machines in case of any power cut, and using access control measures, etc.

Detective controls: These are the controls that are used to detect any vulnerabilities. Vulnerability scanner, security audit, using SIEM system, CCTV, and guards to monitor access.

Corrective controls: These are applied after the attack to ensure all other gaps are filled. Restoring data from backup, forensic examination of any device involved in a breach, restoring plans after the incident, and isolating affected devices from the system are some examples.

Technical controls: Using technical tools to protect data, such as access monitoring tools (PAM), antivirus, user access control, encryption, Endpoint Detection and Response, Network Access control, etc.

Administrative controls: These controls are policies, procedures, and regulations to protect data. For example, through staff training, the data breach problem can be mitigated.

Physical controls: These are designed to prevent unauthorised access to any secure area.

Implementing biometrics, scanning smart cards while entering the premises, logging out from the devices while not in use, implementing a zero-trust policy, etc., are some examples of physical controls.

Tutor Comment: Very comprehensive set of examples and excellent division into categories.

3.2 Explain a basic cyber security framework

You must explain a basic cyber security framework. An example could be: • National Cyber Security Centre (NCSC), 10 Steps to Cyber Security • Centre for Internet Security (CIS) controls.

A cybersecurity framework is a pre-defined structural framework for the IT professional that provides guideline for identifying and managing cybersecurity risks. There are many different frameworks with a variety of functions and features, such as the NIST (National Institute of Standards and Technology) cybersecurity framework, NCSC (National Cybersecurity Centre), Centre for Internet Security (CIS), etc.

I am going to discuss briefly about five steps (identify, protect, detect, respond, and recover) of the NIST framework.

Identify: this is about knowing the system thoroughly to identify what needs to be protected, staff, devices, and business data, for example.

Protect: using tools and techniques to protect data, for example, using strong passwords, encrypting data, limiting user access, etc.

Detect: setting up tools and systems to detect any unusual activity, or something that slipped from the identifying step. For example, firewall or log monitors to detect any incoming threat.

Respond: staying prepared to respond to any incident quickly. For example, if there is any unusual log detected by the system showing access failed many times in a short time gap and suddenly got access for a few seconds, it needs to respond quickly.

Recover: recover normal operations as soon as possible, as it may impact business revenue. So, NIST is a very simple and straightforward cybersecurity framework to protect an organisation.

Tutor Comment: Good coverage of the NIST framework and good mention of other commonly used frameworks.

3.3 Evaluate a cyber security framework

You must explain a basic cyber security framework. An example could be: • National Cyber Security Centre (NCSC), 10 Steps to Cyber Security • Centre for Internet Security (CIS) controls.

3.3 Should companies encrypt data or not? Are there advantages to not encrypting? What do NIST or NSCS frameworks recommend?

Encryption is a way of changing text into something that the hackers cannot reveal.

Advantages of encryption: Encryption makes data secure; if it's in the wrong hands, they can't read it. It is compiled with laws such as GDPR, and with audits. It is cost-effective. Because when attackers attack and get information, the company will need to pay a ransom, which will be more than the encryption cost. Further, it is timesaving. Simply, a company may think, encryption takes time, and it slows down work. But the fact is that, when that company gets attacked, it needs to spend more time

to investigate, put more experts (cost), and it has to pause the business operation, which leads to revenue loss. So, factually, encryption takes less time.

Disadvantages: One common disadvantage is that data can be lost if the encryption key is lost. It makes business functionality slow, adds extra work for employees, and requires expertise in obtaining or restoring data.

Now, a basic framework is a simple framework that is straightforward and with enough details to protect an organisation. However, it may not be the complete one on its own. Many frameworks are used by IT professionals to protect information assets. The NIST is one of them. It comes with five steps: identify, protect, detect, respond, and recover. The NIST's recommendations link the framework with encryption in its 2nd step, protect. In the protection step, it says to implement safeguards to secure assets, which indicates that information assets (data) should be encrypted and secured in their transition. For example, using TLS (Transport Layer Security) to encrypt data in transit. Further, step 4, respond, also indicates the encryption towards the restoring phase. It could involve replacing lost encrypted data with a backup following a breach.

Therefore, I would recommend using encryption as an important action for cybersecurity professionals. The minor problem of losing the encryption key can be overcome by saving it somewhere safe.

Tutor Comment: Very good analysis of encryption pros and cons and good inclusion of relevant NIST recommendations.

Learning outcome 4: Be able to apply a cyber security control

4.1 Explain how to apply controls

You must explain how to apply a minimum of four cyber security controls; you will have identified these in 3.1.

I am using a Chromebook. I will apply four cybersecurity controls: set folder permissions, check CPU and memory usage, updates, and antivirus scan.

Folder permissions: folder>right click on folder>click on the three dots on right>choose to share as link/copy.

CPU and memory check: search bar>settings>About Chrome OS>Diagnostics

Updates: Settings>three lines>About ChromeOS>check for updates

Antivirus scan: Settings>Reset and cleanup>Cleanup computer

Tutor Comment: Good selection of controls and good concise step-by-step instructions.

4.2 Implement a basic cyber security control. [Download the required document here.](#) When it has been completed, upload the document below:

You must implement a basic cyber security control, an example of this could be demonstrating how to give access/deny access to a folder or drive.

Tutor Comment: Thank you, Rozina. You uploaded clear images illustrating update monitoring as well as CPU and memory usage monitoring on a Chromebook.

4.3 Justify the implementation of the chosen cyber security control

I carried out some cybersecurity controls like checking folder permissions, updates, and encryption. Encryption and folder permissions are linked to the Principle of Least Privilege. Updates will ensure the functionality and security of systems, apps, for example. I think these are good practices and should be carried out on a regular basis. So, the information assets will be protected.

Tutor Comment: Thoughtful and detailed reflection on your chosen controls.

4.4 Explain why a control might not be applied

You must explain reasons why a control might not be applied, for example, when is doing nothing a better option?

There are several reasons that a company might not implement cybersecurity controls, depending on the size and type of business. For example, a small company can use passwords, MFA, and biometrics instead of hiring cybersecurity professionals.

One of the reasons is cost. Some companies may not consider the cost of recruiting cybersecurity professionals, necessary devices for physical controls (CCTV), vulnerability scanner, antivirus, data encryption, etc.

Another reason can be compatibility issues with older devices or software that the company needs to use.

Further, legal restrictions can act as a barrier for control, encryption, for example, in China.

Tutor Comment: Good examples of situations when controls are not applied or required.

Conclusion

1. Where in this unit did you use AI to support your work?

If not applicable to you, please answer "N/A"

Sometimes Grammarly for spelling as it came.

Tutor Comment: You occasionally made use of AI spell-check tools to make your text more professional; the content itself is based on your own ideas and class discussions as well as the researched material.

2. Which AI tool(s) did you use?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Grammarly

3. On what date(s) did you use the AI tool(s)?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

I confirm that the evidence listed above and enclosed is my own work and was carried out under the conditions and context specified in the standards, as such no plagiarism was conducted during the completion of this portfolio.

TYPE YOUR NAME:

Rozina Khatun

Tutor Comment: Criteria met

DATE:

07/11/2025

Tutor Comment: Criteria met

Tutor feedback

COMMENTS:

Tutor Comment: In this part of the portfolio you clearly put significant effort into your answers and demonstrated good engagement with the topic. You answered every section and provided a wide range of examples, which shows developing knowledge of cybersecurity concepts. In particular, there is good understanding of penetration testing, vulnerability scanning and social engineering testing. You covered multiple types of testing and gave suitable examples. Your descriptions of penetration testing (black box, white box, grey box), vulnerability scanning and social engineering testing are clear and accurate. You also explained the importance of testing and why retesting is necessary. This shows developing understanding of the overall testing lifecycle. You identified a variety of vulnerabilities across networks, systems, cloud and physical security. Your step-by-step response to vulnerabilities is well structured and appropriate. The example

communication you provided is relevant and shows a good attempt at professional writing; the sample poster is eye-catching and clear.

You correctly described preventive, detective and corrective controls as well as administrative, technical and physical controls. Your explanation of the NIST framework shows understanding of the core functions. Providing Chromebook-based examples of controls shows practical understanding. You also gave realistic reasons why a control might not be applied, such as cost and compatibility.

*Some answers are rather long and drift from the question; some points are repeated in multiple sections. Using shorter paragraphs or bullet points and keeping each answer aligned to the assessment criteria would improve clarity. There are some errors such as run-on sentences, inconsistent capitalisation, missing commas and full stops. "something slipped from identifying step" is unclear; "this is most easiest way" should be * this is the easiest way. Proofreading or using a grammar-checking tool more consistently before submission would increase the professional quality.*

Overall, you made a very good effort and showed developing knowledge of cybersecurity testing, vulnerabilities, controls and frameworks. You demonstrated strong interest in the topic, answered sections in full and enriched your answers with many relevant examples.

I confirm that this student has achieved all the requirements of the units with the appropriate evidence/s enclosed. Assessment is valid, authentic, reliable, current and sufficient.

ASSESSOR FULL NAME:

Tutor Comment: Paola Palazzo

ASSESSOR SIGNATURE:

Tutor Comment: Paola

Unit 4: Cyber security incident response

Learning outcome 1: Understand what is meant by a cyber security incident response plan

1.1 Describe what a cyber security incident response plan is used for.

You should include a reference to the checklist as well as the overall plan.

1.2 Explain when a cyber security incident response plan is used.

A cybersecurity incident response is a pre-planned document helping the cyber professionals to detect, manage and recover from cybersecurity incidents. It is a plan with a clear structure.

The Incident Response Plan (IRP) provides detail information and tasks for everyone involved to mitigate the issues and resume the daily operations as soon as possible.

IRPs tend to be very important document with depth information for several sections depending on the type of attacks as well as the type of company. It is also useful to keep a track of what has been done and what needs to be done, for example.

The IRP is activated whenever a suspected incident is taking place. For example, a system getting slow may indicate the presence of worm, the vulnerability scan logs indicate repeated attempts to login or any staff reports a phishing attempt.

An IRP is activated in response to several cybersecurity threats such as Malware, Data breaches, Phishing campaigns, Unauthorised access, etc.

Tutor Comment: Good explanation of why an IRP is created, when it is activated and its goals.

1.3 Describe the stages of a cyber security incident response lifecycle

There are a number of published incident response lifecycles available: you must describe one of them.

Several IRP lifecycle frameworks are available for the cybersecurity professionals to follow responding to the incident. Some common ones are: NIST 800-61, SANS and ISO 27035.

One common framework of NIST's steps includes:

Step 1. Preparation: at this first step, conducting risk assessment, organizing staff training, monitoring software, designing authorized use policies, establishing communication protocols, etc. are done to make sure the team is ready to response the incident effectively.

Step 2. Detection and Analysis: monitor the systems to identify any incidents when they arise using SIEM systems, IDS/IPS, etc.

Step 3. Containment: this stage is to apply a short-term and immediate solution, for example, block the IP address when the system detects any abnormality.

Step 4. Eradication: apply long-term solution, for example, carry out a complete check for computers that are affected before connecting them again.

Step 5. Recovery: restoring services and systems as normal after the incident once the eradication step is taken.

Step 6. Post-Incident Review: use lessons from previous incidents, review the IRP accordingly, provide training, if necessary, modify policies when require, or get new software for better protection.

Tutor Comment: Good coverage of the NIST Incident Response lifecycle and good mentions of other standards.

Learning outcome 2: Be able to develop a cyber security incident response plan

2.1 Explain why it is important to maintain an up to date cyber security incident log.

A cybersecurity incident log plays a vital role in responding the cyberattack. It is a necessary and valid document that is required in response to compliance, training, insurance, risk management, etc. Because the incident logs recorded the detail of attacks and how it was solved, that information can help to design the new IRP. Cyber professional can understand the pattern of attack and take necessary steps to resolve the issues.

Further, an up-to-date log is a legal requirement for the company insurance. It is also useful for staff training as staff can stay up to date. Moreover, the logs that the IT staff used to identify the problem, should be recorded and kept as evidence. Therefore, an up-to-date incident log is very important.

Tutor Comment: Very good coverage of the importance of up-to-date incident logs. You could expand on the logs' forensic value and supporting investigations.

2.2 Explain the steps to be included within a cyber security incident response plan.

2.3 Explain why it is important to have a cyber security incident response plan.

2.2 A cybersecurity incident plan should include all the steps that are in detail and essential to protect the business organisation and its assets. Frameworks like NIST or SANS recommended the following steps to be included in the IRP:

Preparation step in to ensure that there is risk assessment plan, communication protocols are set, staff training is organised and the entire team is ready to act. The next step, identification, which involves detecting and analysing the threat thoroughly to make sure the actual incident can be spotted. Containment is the next step for short-term solution. The other two steps, eradication and recovery are for isolating the affected devices, removing the threats and recovering from the incident as soon as possible. Post-incident is about applying the knowledge and experiences that are learned from the incidents, analysing the current plan and updating them accordingly.

In practice, an IRP report follows the above but includes more sections such as:

- >Executive summary: a section including an index containing the content of the report
- >Incident description: the possible types of incidents that the company may have to deal with
- >Incident analysis: impact of each type of incidents
- >Roles and responsibilities: details of the tasks that will be allocated to every responsible staff
- >Communication protocols: informing the incident to the right person at the right time through proper communication channel, for example, JLR staff should be notified of a breach within 72 hours
- >Containment: the immediate action to get the short-term solution
- >Eradication: the long-term measures to be applied to secure the system
- >Recovery: resuming operations after resolving issues
- >Post-incident activity: keeping record of what has been done, what went well and what was not, what can be done better next time
- >Recommendations / Actions: any recommendations of how things could be done better way, any new software, changes in policies, etc.
- >Appendix: an index of vulnerability logs tracking such as when it was done, what was the pattern, for example.

An effective operation is impossible without a proper plan. If the team members are not clear with their tasks, guidelines and resources, no one will be able to do the job properly. Therefore, the entire operation will go in vain. As a result, the company will waste money, time and human power. It will end up with legal penalties and will lose the reputation. So, having an IRP in place, will allow the company to perform the incident operation effectively.

Tutor Comment: You gave a comprehensive answer covering the IR lifecycle, report structure and importance.

2.4 Develop a cyber security incident response plan for an organisation

[Download the document here.](#) When it has been completed, upload the document below:

Tutor Comment: Thank you, Rozina. Your Incident Response Plan has a clear structure following the standard IRP lifecycle. Roles and teams are clearly listed, with multiple people per team, which is realistic. The incident detection methods are appropriate and include OSINT, automated alerts and traffic analysis. The Containment strategies are relevant and show good understanding of priorities. The Recovery objectives are clearly articulated.

Some roles list multiple names but could more clearly show who is responsible for what. The IT Manager Adam Smith is assigned a containment task, but as a manager he may not be the technical executor: consider delegating tasks to security engineers instead.

Some details could be revised: for instance, if worms are likely and self-replicating, the priority should be high. You could specify when failed login attempts become high priority, e.g. repeated tries from the same IP. Ensuring all data is encrypted is prevention rather than containment. Containment should be actions like disconnecting affected systems, revoking compromised credentials or blocking malicious IPs. The Recovery plan could include a communication plan for customers and suppliers.

Overall, your IRP shows a solid understanding of incident-response fundamentals and is well-structured.

Learning outcome 3: Be able to develop an incident post mortem report

3.1 Explain what is meant by incident post mortem.

3.2 Explain the structure of an incident post mortem.

3.1 Incident post-mortem report is the investigation plan that is after the incident. It is to analyse what has happened, what was the cause, how did that happen, where was the gap in the system - all these in detail. It can also be named as post-incident report or post-incident review. The reason for doing this is to protect the organisation from the similar type of incident in future. Also, it is a good source for the professional to understand the pattern of attack. Therefore, the professional can be trained on those gaps.

3.2 The structure of an incident post-mortem would include the following:

- a. Incident summary: a brief overview of what type of incident is that and summary of it
- b. Incident details: how it was happened, symptoms, etc.
- c. Timeline of events: information about the time period of the incident, reporting time and date, chronology of further developments
- d. Impact analysis: impact in detail of that incident to the organisation, for example, affected system, services, users, data loss, financial loss, etc.
- e. Root cause analysis: the main cause of the incident, what was the loop hole, for example
- f. Response evaluation: how the IT team responded
- g. What went well: which measures worked well
- h. What did not go well: what containment or eradication went wrong
- i. Lessons learned: learning from the gap and staying prepared to protect the organisation from similar attack in future
- j. Actions: identified actions that would help to respond future incident, for example, new devices, softwares, policies, et.
- k. Appendix: better to keep record of logs, charts, team comments, records of interviews with internal threats, etc. for future practice.

Tutor Comment: Good identification of key sections of a post-mortem report and good explanation of their purpose.

3.3 Consider the importance of the following when carrying out an incident post-mortem: • integrity • rigour • discipline

Integrity, rigour and discipline are the three principles of an incident post-mortem. They make an effective investigation. These should be applied when creating a post-mortem so that it can be more valuable.

Integrity: the report should be ethical, transparent and honest. Instead of including blaim, it should inclde what was learned that can be applied in future to protect the organisation. For example, a staff clicked on a link which gave access to attackers. Here, the best approach will be to organise staff training regularly making sure that they are aware of threats that might come.

Rigour: the report include incident facts, impacts, root cause, etc in detail, nothing should be hidden nor ingnored. For example, containment and eradiction steps (Fishbone diagrams, logs, system metrics, etc.) should be carried out thoroughly.

Discipline: report should follow systematic processes. It should be standard. Any recommendations, feedback should be recorded and actionable. This should provide guidelines according to ISO 27035, for example.

All the above three principles make the post-mortem report more effective. Without one, it is incomplete.

Tutor Comment: Good coverage of how each principle works together to ensures accurate, actionable and unbiased reports.

3.4 Create a post mortem report of an incident. [Download the file here.](#)

When it has been completed, upload the document below:

Tutor Comment: Thank you. In your Postmortem Report on the JLR Cyberattack you made excellent use of multiple sources to support the timeline and root cause. You showed strong grasp of supply-chain compromise (from LG Electronics to Jira credentials to JLR). Good explanation of business impacts, financial losses, manufacturing shutdown. Clear outline of contributing factors: unpatched systems, poor segmentation, old credentials. Correct identification of the threat group (HELLCAT). Very comprehensive Lessons Learned section.

The root cause analysis contains very good information but could be structured more clearly in initial access, privilege escalation, lateral movement, data exfiltration, ransomware deployment intent. You could add some post-incident details such as whether backups were affected, whether JLR paid ransom or refused and the duration of full operational recovery. You could add a conclusion summarising what went wrong, what was fixed and what the organisation must do long term: this would make the report feel more complete.

Some sentences are unclear or need refinement. For example, in the sentence "Few power plants were halt" it is unclear what power plants you refer to: you likely meant that JLR manufacturing sites paused. "English-speaking hackers" should specify that they are native English speakers, recruited to make phishing or vishing communication sound more natural.

Overall, your postmortem is a well-researched report that effectively captures the scale, causes and consequences of the JLR cyberattack, with strong use of sources and detailed insights into the supply-chain compromise.

3.5 Reflect upon the report and make recommendations based on the findings

Some common recommendations that any company can follow would be: provide staff training regularly, implement strong password policies (12-15 mix characters), apply MFA, install updates, backup data using 3-2-1 steps, encrypt data in transit and rest, keep a separate copy of the backed up data, perform audit, review and monitor the incident post-mortem report.

Tutor Comment: You gave practical recommendations and showed good awareness of the 3-2-1 backup rule and encryption. You could include continuous monitoring or regular tabletop exercises.

Conclusion

1. Where in this unit did you use AI to support your work?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Your text appears original and you effectively combined your own ideas with points and examples from class discussions

2. Which AI tool(s) did you use?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

3. On what date(s) did you use the AI tool(s)?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

I confirm that the evidence listed above and enclosed is my own work and was carried out under the conditions and context specified in the standards, as such no plagiarism was conducted during the completion of this portfolio.

TYPE YOUR NAME:

Rozina Khatun

Tutor Comment: Criteria met

DATE:

12/11/2025

Tutor Comment: Criteria met

Tutor Feedback

COMMENTS:

Tutor Comment: In this unit you provided thorough, well-structured answers and showed clear understanding of the purpose of IRPs, post-mortems and common frameworks such as NIST 800-61 and ISO 27035. Your explanations are detailed and show good growing confidence with cyber-security terminology.

You explained clearly that an IRP is a pre-planned document used to detect, manage and recover from incidents and you correctly identified when an IRP should be activated (e.g. suspected malware, phishing, unusual system behaviour). You showed understanding of different types of incidents: malware, data breaches, phishing, unauthorised access. You correctly outlined the NIST incident response lifecycle stages; good examples provided (blocking an IP, SIEM/IDS monitoring, long-term eradication). You covered multiple important reasons for keeping up-to-date incident logs: compliance, insurance, training, pattern identification; you correctly noted that logs provide evidence for investigations. Very thorough explanation of the IRP structure in practice and strong justification for why an IRP is essential (cost-saving, legal protection, clarity of roles). Your submitted IRP shows a solid understanding of incident-response fundamentals and is well-structured.

You showed clear understanding of the purpose of a post-mortem. Good detail in the structure section, showing strong awareness of professional formats and appropriate examples such as logs, interviews,

charts. Excellent understanding of the three principles of integrity, rigour and discipline with strong examples showing how each principle supports a reliable post-incident review. Your submitted post-mortem is a well-researched report that effectively captures the scale, causes and consequences of the JLR cyberattack, with strong use of sources and detailed insights into the supply-chain compromise. You gave practical recommendations: MFA, staff training, backups, password policies, patching; good awareness of the 3-2-1 rule and encryption.

Your work demonstrates British Values through mentions of respect for rules and standards (ISO/NIST), its emphasis on transparency, integrity and accountability and its focus on protecting organisations and individuals. You also referenced staff training and awareness, which supports Equality, Diversity and Inclusion, ensuring all employees can understand and respond to cyber threats fairly and confidently.

*There are a series of spelling errors and inconsistencies. Correcting these will hugely improve clarity and professionalism. For examples, Incident Response should be *Incident Response; detail information should be *detailed information; designed should be *designed; phising should be *phishing; Maleware should be *Malware.*

Overall, you showed strong understanding of cybersecurity frameworks and wrote in good detail.

DATE:

Tutor Comment: 11/11/2025

ASSESSOR FULL NAME:

Tutor Comment: Paola Palazzo

ASSESSOR SIGNATURE:

Tutor Comment: Paola

Unit 5: Understand legislation and ethical conduct

Learning outcome 1: Understand legislation relating to cyber security

Unit summary: The learner will gain an understanding of the legislation surrounding cyber security. They will understand international law relating to cyber security and the importance of information security standards, moving onto gaining an understanding of ethical conduct within cyber security.

1.1 Describe how legislation impacts on cyber security

Your description must cover a minimum of four pieces of legislation. It is important that current and relevant legislation is covered.

Some UK laws related to cybersecurity include the Computer Misuse Act 1990, Official Secrets Act 1989, Communications Act 2003, Data Protection Act 2018 / UK GDPR, Directive on security of network and information systems (2016/1148), etc. But the four of them for cybersecurity are the Computer Misuse Act 1990, the Communications Act 2003, the Data Protection Act 2018 and the NIS2

Directive.

Communications Act 2003: The Communications Act 2003 (replacement of Telecommunications Act 1984) is an Act of the UK Parliament which came into force on 25 July 2003. This can be provided as evidence in legal cases. This act criminalises cyberbullying and puts the responsibility on the service providers. They should keep a record of any inappropriate communication sent from the service and may need to submit that as evidence in case if there is any legal cases.

Computer Misuse Act 1990: The Computer Misuse Act 1990 is an act to make provision for securing computer devices against unauthorised access, modification, or connection purposes. The fact that a pen tester (cybersecurity professional) can be prosecuted without obtaining an explicit authorised order for this act.

The Data Protection Act 2018 / UK General Data Protection Regulation (UK GDPR): This act is about how to collect personal data, store and use it within the UK law. This dictates that companies take measures such as encryption and user access control to protect the available data. Any data breaches should be reported to the Information Commissioner's Office within 72 hours. Otherwise, a penalty will be issued.

Directive on security of network and information systems (2016/1148)/ NIS2 Directive: This act is to enhance cybersecurity across multiple critical sectors such as energy, transport and healthcare. It aims to protect the critical infrastructure by providing guidelines on how to protect sensitive data, store it, and report any breach within 72 hours. It also encourages regular risk assessment. Unfortunately, several attacks took place on water filtration plants worldwide, for example.

Tutor Comment: Well-chosen examples of relevant UK laws related to cybersecurity. NIS2 is an EU directive; the UK is currently preparing similar equivalent legislation.

1.2 Explain trends in international law for cyberspace

The trends of international laws in cybersecurity are continuously changing or being modified due to the arrival of different new technologies. Many geopolitical and economic factors can affect the rules and regulations regarding cybersecurity. Increased cooperation between states can ensure that cyber criminals can be prosecuted. Further, the Council of Europe's Budapest Convention on Cybercrime is an international treaty that aims to regulate cooperation on cybercrime between states. Another one is the Paris Call is an appeal by French President Emmanuel Macron for more cooperation between countries in the fight against cybercrime. Furthermore, cyberweapon regulations are a noticeable trend; for example, the Stuxnet worm was used to attack Iranian power stations or NotPetya. In this kind of incident, common types of guidelines are in the Tallinn Manual on the International Law Applicable to Cyber Operations.

Tutor Comment: Good summary of some international trends and good mention of related treaties and appeals.

Learning outcome 2: Understand information security standards

2.1 Identify ISO standards related to cyber security.

2.2 Explain how ISO standards are used to support cyber security.

It is important that current and relevant standards are covered.

2.1 The ISO (International Organisation for Standardization) is an independent, non-government international organisation that maintains standards for quality products and services. Although it is voluntary, it helps to build trust among customers, stakeholders and employees by providing guidelines to deliver the best quality products and services. Popular companies prefer to have ISO badges on their website for their reputation and brand image.

The ISO covers several areas, for example, ISO 9001 for quality management, ISO 14001 for environmental management, ISO 45001 for occupational health and safety, ISO 13485 is for medical devices, etc. The ISO standard series 27000 is specific to cybersecurity. ISO 27001 and 27002 from 27000 relate to data security and recommend using encryption, multiple authentication and some other measures to protect the organisational data. Further, the ISO 27032 provides guidelines on system protection from cyber attacks. Next, the ISO 27017 is for cloud service protection and 27018 is for data protection within the cloud. Not least, but may be the last trend, which is the standards for quantum computers are developing.

2.2 The standards provide guidelines to help companies with risk assessment, system protection by complying with laws.

For example, the ISO 27701 (extension of 27001) instructs businesses to comply with the data privacy requirements and avoid fines. It also promotes a culture of continuous development in organisational assets by providing access control guidelines and incident management, for example.

Tutor Comment: Good coverage of some relevant ISO standards and good inclusion of current ones such as cloud storage.

Learning outcome 3: Understand ethical conduct within cyber security

3.1 Describe ethical conduct within cyber security

You must include: • maintaining confidentiality • adherence to applicable laws • promoting information security • refraining from conflicts of interest.

Conducting cybersecurity tasks professionally and ethically is vital to maintain trust, protect valuable sensitive information and ensure proper use of technology.

Ethical conduct includes maintaining confidentiality: IT professionals have access to highly confidential data and they must protect it, not leak or misuse it. They should control access by limiting the user, for example. Also, they should conduct the pen test by obtaining prior permission to do so to avoid legal pressure. This makes them less susceptible to bribes or blackmail.

Adherence to applicable laws: Cybersecurity professionals should not engage in hacking, unauthorised

access, or violate the ethical standards for any motivation. They should comply with local, national and international laws in every step of their tasks.

Promoting information security: An IT professional can provide all the necessary training to staff to keep them up-to-date. For example, train staff about phishing, pretexting, etc.

Refraining from conflicts: Staff who work for more than one company or have interests in a company, for example, company shares and personal connections, should disclose this and should not abuse the connection for personal gain.

Therefore, we can see that ethical conduct is a protective shield for cybersecurity professionals.

Tutor Comment: Very well thought out examples of ethical conduct.

3.2 Identify unethical conduct within cyber security

You must include: • sabotage • disclosing or misusing confidential information • maliciously injuring the reputation or prospects of an individual or business.

Unethical conduct within cybersecurity is when security professionals break the principles, standards or legal boundaries of cybersecurity by their actions or decisions. The professionals should behave ethically by following the rules and principles of cybersecurity and avoid misuse of their skills, knowledge and power for any bad intentions. There are many examples of unethical conduct, but some of them can be sabotaging company systems or data for revenge or stealing company clients; selling staff/company data on the dark web; spreading false information to harm the reputation of a company; abusing insider knowledge to conduct industrial espionage; negligence in conducting tests and reporting results to harm the company's image and giving chances to rivalries; insider employees' negligence to update softwares, ignoring or hiding other vulnerabilities, etc. All of those are against cybersecurity rules and principles.

Tutor Comment: Good account of unethical conduct.

Conclusion

1. Where in this unit did you use AI to support your work?

If not applicable to you, please answer "N/A"

Sometimes I have used Grammarly for spell check.

Tutor Comment: You made effective use of AI-based grammar and spell-check tools to give your work a professional finish; the content itself was grounded in your own ideas, class discussions and some researched material.

2. Which AI tool(s) did you use?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

3. On what date(s) did you use the AI tool(s)?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

I confirm that the evidence listed above and enclosed is my own work and was carried out under the conditions and context specified in the standards, as such no plagiarism was conducted during the completion of this portfolio.

TYPE YOUR NAME:

Rozina Khatun

Tutor Comment: Criteria met

DATE:

12/11/2025

Tutor Comment: Criteria met

Tutor Feedback

COMMENTS:

Tutor Comment: In this section you showed a solid understanding of key cybersecurity legislation, ISO standards and ethical principles. Your work is detailed, it uses relevant examples and it demonstrates good awareness of how laws and standards apply in real situations.

Good coverage of legislation: you correctly identified the major UK cybersecurity laws and you explained the purpose and impact of each law. Your explanation of data breach reporting requirements and pen-testing authorisation is accurate and you linked laws to real-world consequences (e.g. penalties, evidence, responsibilities of service providers). Strong explanation of international trends: you highlighted international cooperation, treaties like the Budapest Convention and initiatives such as the Paris Call. You referenced cyberweapons (Stuxnet, NotPetya) and the Tallinn Manual, showing strong contextual awareness. You recognised issues like geopolitical influence and evolving technology. Good understanding of ISO standards: you identified relevant cybersecurity-related ISO standards in the 27000 series; you explained their purpose clearly, including cloud-specific standards (27017, 27018). You recognised emerging areas such as quantum computing. Your explanation of how ISO standards support risk assessment and legal compliance is accurate.

The ethical and unethical conduct sections are well developed: you clearly explained confidentiality, lawful behaviour, conflict of interest and responsible use of privileged access. Your examples of

unethical conduct (insider threats, espionage, sabotage) are relevant and realistic. Shorter, clearer sentences will improve readability. Some sections repeat the same idea in different words. For example, you mention customer trust and ISO badges multiple times. Try to keep each point concise and avoid repeating concepts. Overall, this is a very good submission showing strong understanding, good research and generally clear explanations. Demonstrating through examples and linking concepts to real cybersecurity practice are real strengths in your writing.

DATE:

Tutor Comment: 12/11/2025

I confirm that this student has achieved all the requirements of the units with the appropriate evidence/s enclosed. Assessment is valid, authentic, reliable, current and sufficient.

ASSESSOR FULL NAME:

Tutor Comment: Paola Palazzo

ASSESSOR FULL NAME:

Tutor Comment: Paola

Unit 6: Professional skills and behaviours for cyber security

Learning outcome 1: Understand behaviours required for a career in cyber security

1.1 Explain the importance of managing and promoting a positive digital identity

You must include within your explanation that a digital image or footprint can be traced and used by third parties such as employers.

Managing a positive digital identity is important in this overflooded digital world. Employers, social media, government, local organisations and business institutions - all are using digital identity to verify. Now, the question is "Is it safe?". There is no clear answer to it. This is why positive digital identity promotion and management play a vital role. Social media, such as LinkedIn, can be used as a marketing tool (both by employee and employer) to advertise jobs, skills, previous experience and certificates. A job seeker or learner can follow a relevant company or group and make a network. A company can check a candidate's profile to see what the qualifications, experiences, skills, etc. are for the recruitment process (shortlisting, interviewing and job offering). Therefore, a candidate should update the profile regularly to make sure the employer gets a positive image. A positive digital identity also prevents fraud. For example, it ensures the right person for the job through ID verification, which then can be used by other 3rd parties such as DWP.

Tutor Comment: Excellent explanation of why a positive digital identity matters, including details on LinkedIn, credibility and online behaviour.

1.2 Describe possible employee screening checks that an employer might carry out

You must cover: • Disclosure and Barring Service (DBS) check • guilty by association check • security checks such as terror lists, address checks and employment verification checks • credit checks.

Some employers do employee screening checks, but not all. HR personnel organise this check to make sure that the employees will not damage the reputation of the company. Some of the checks that companies usually do are Disclosure and Barring Service (DBS), Right-to-work, medical check for fitness, reference checks/employment verification checks, social media checks, address checks, guilty by association checks, etc.

DBS check: This check is about prior conviction checks. It is to investigate if there are any legal obligations. There are three levels of this check such as Basic, Standard and Enhanced. The Enhanced level is related to children, vulnerable adults, health care, etc. The DBS certificate is valid for 3 years.

Guilty by association check: This check will ensure whether the candidate is involved in any criminal activities or groups. This includes an investigation into family and work-based connections. Normally, critical organisations such as the government, law enforcement or cybersecurity carry on this check.

Security checks: The security check includes terror lists, address checks and employment verification checks. The organisation can check the candidate's address (some may have a specific time demand for that address, normally 3 to 5 years). They can also check if the candidate is involved with any terror group (especially security job). If the outcome of checks is negative, the employer can withdraw the job offer.

Identity checks: The ID checks enable the employers to verify the candidate's identity, National Insurance Number, address, etc. It is also to check if any illegal activities are involved against that address.

Credit check: The check is to tell the employer about the candidate's credit score, loan or credit card payment history. The candidate needs to provide consent to do this check.

Tutor Comment: Strong coverage of screening checks including DBS, guilty by association, terror lists and credit checks.

1.3 Consider potential consequences of unsatisfactory findings as a result of employer checks

You should include: • inability to get security clearance • inability to work in particular areas • inability to work for high profile employers • a requirement to give an explanation of the results (e.g. non-payment of fine or association with an individual with a criminal record).

If the checks come up with a negative response, the employer can withdraw the job offer. For example, if the company finds that the candidate's degree is fake, they can sue him/her. Some organisations, e.g., the civil service, can prevent a candidate from working in the same department for two roles. High-performing job roles (such as an IT security role) can withdraw the job if any checks come with a negative result. The candidate can face legal issues (fines) for false information or statements.

Finding any unsatisfactory element in checks can damage the organisation's reputation. For example, finding a candidate's connection with a terror group can put the company at risk of a cyberattack. Fines upon the employer are imposed by the ICO and they could be very high.

Tutor Comment: Good examples of consequences of unsuccessful checks. You considered both employer and employee viewpoints, which shows analytical thinking. Ideally, also cover the need to provide an explanation.

1.4 Describe the following security clearance levels:

- **BPSS (Baseline Personnel Security Standard)**
- **SC (Security Checked)**
- **DV (Developed Vetting)**

You must describe each of the security clearance levels including when they are used.

Different organisations use different screening systems. One example is civil service. They use a three-level check.

The first one is the Basic Personnel Security Standard (BPSS): This one is to check the candidate's identity, nationality, past 3 years employment history, criminal record, explanation for time spent abroad (6 months or more in the past three years), etc.

The 2nd one is the Security check. It includes a BPSS check, security questionnaire, spent and unspent criminal records, credit history, candidate's overseas activities, etc. This is because the candidate will have access to sensitive data; therefore, it is essential to check whether it is a good fit or not. The check has a 10-year validity for civil servants and 5 years for contractors.

The 3rd level is the Developed Vetting (DV). It is used for senior-level positions, as they have access to highly sensitive data, for example, nuclear material. The check includes BPSS, DV security questionnaire, spent and unspent criminal records, departmental record, credit and financial check, security service (M15), detailed interview by trained investigation officer, security questionnaire from 3rd parties, etc. The check needs to be renewed after 7 years for civil servants, more often for contractors.

Tutor Comment: Clear understanding of BPSS, SC and DV levels, including validity periods and who they apply to.

1.5 Explain how bias can influence cyber security

A biasness is an unfair judgment or treatment. Several types of bias in cybersecurity are gender, age, affinity, ethnicity, educational and algorithmic. These have their impact on cybersecurity.

Gender bias: In many organisations, men have an ordinary thought that men are a better fit in the security job role than women. This bias can control the salary range too, for example, lower salaries for women than men. Different training organisations for women are an example of gender bias.

Age bias: Many employers in the organisation may think that old heads are better than new heads, as they have more experience. Or some can assume that young heads are a better fit as they have more time to serve the company. Therefore, age is a biased element.

Affinity bias: Some employers may select candidates who seem similar to them, for example, a degree from the same university or discipline, live in the same city.

Ethnic bias: An employer can favour a particular national for an IT role, for example, an Indian national can do IT job better. Or, an employer can favour an applicant from the same background.

Educational bias: It is when the employer favours a candidate with the same degree as them.

Algorithmic bias: AI recruitment process can be biased if proper data is not fed.

Another one can be vendor bias, where the company keeps buying things from the same company.

Any of those bias in hiring limits the IT teams' diversity, creativity and productivity.

Tutor Comment: Very good range of biases described, showing understanding of the impact on hiring and on vendor choices.

1.6 Describe the benefits of a security by design mindset

Security-by-design is when a system or product is described in the ground phase. The IT professionals should operate with security by design principles in mind in their daily activities. This will help them perform better by protecting them as well. It will keep them on the safe side as they will conduct the operational tasks by following the rules and principles of cybersecurity. For example, the Zero Trust principle should be applied with external contacts (emails, phones, calls, texts, etc.)

Another example is the application of the Principle of Least Privilege, which ensures limited access.

Using MFA and encryption is a defense-in-depth practice for cybersecurity professionals.

Tutor Comment: Clear coverage of security by design benefits, with practical examples like least privilege and zero trust principles.

Learning outcome 2: Be able to identify skills required for a career in cyber security

2.1 Identify skills required for a career in cyber security

A mixture of soft, technical, analytical and leadership skills is required for a cybersecurity role.

Useful technical skills may include digital skills, knowledge of applications (Wireshark, Splunk, Kali, Linux, etc.), coding language skills (Ruby, Python, SQL, Java, etc.), Pentesting, network security, data visualisation tools (Power BI) to make reports, Incident response knowledge, good knowledge of computing components, etc.

Analytical skills are related to problem-solving skills. This includes analytical or logical thinking, the ability to work in a team and individually, think beyond, perform research to gather necessary information and extract it, the ability to produce an insightful report, the ability to carry on an investigation, etc.

Soft skills include communication skills, using different resources (Microsoft Office, for example), interpersonal skills, being able to work under pressure, coping with change, being willing to learn for personal development, etc.

Also, Cybersecurity professionals should be aware of rules and regulations. Many employers may require this legal knowledge.

Along with the above skills, leadership skills make a positive impression on employers. For example, employers may see that this skill will enable the candidate to lead the security team.

Tutor Comment: Well-rounded list of technical, analytical and soft skills needed for a cybersecurity career.

2.2 You must carry out an analysis of your skills.

You could rate and rank your skills, utilise feedback from others or use an approach such as a SWOT (Strengths, Weaknesses, Opportunities and Threats) or SOAR (Strengths, Opportunities, Aspirations, Results) analysis.

Please check question 2.4 file area.

Tutor Comment: In your SWOT you provided a detailed and well-structured list of strengths that clearly demonstrate strong potential for a cybersecurity career. Including specific technical strengths (programming, scripting, compliance, Kali/Linux knowledge) as well as academic achievements (PG Diploma, NCFE Level 3) makes your analysis highly credible. Your mix of technical abilities, industry knowledge and real-world experience (retail operations, fast-paced environments) shows versatility and adaptability, which are important in cybersecurity roles. The inclusion of your commitment to continuous learning and a proven track record of interventions adds depth and professionalism. You identified realistic weaknesses such as the need for more cloud knowledge and limited real-life experience. This is excellent self-awareness. In Opportunities you showed strong awareness of market trends and industry needs such as remote work, compliance requirements and advances in AI; this demonstrates understanding of the external environment and how it can support your growth. Threats are relevant and realistic: you correctly identified challenges such as competition, rapid technological change and evolving threats. This shows good understanding of the dynamic nature of the field and the importance of continuous development.

You could strengthen the weaknesses section by adding specific technical areas you still want to improve (e.g. SIEM tools, network defence, cloud security).

Overall, this is a very strong SWOT analysis: it is detailed, relevant and well-linked to cybersecurity career requirements.

2.3 Assess own skills against those required for a career in cyber security.

I have the necessary technical skills for cybersecurity roles. For example, I have good digital skills. With my application knowledge (Kali, Linux), coding and scripting knowledge (Python, SQL), data visualisation skills (Pivot tables, Power BI), I can maintain software development, automate cybersecurity tasks, protect databases against SQL injection, and produce insightful reports from incident analysis.

My response examples include - install a verified update or patch / restore data from a backup following a ransomware attack / modify a database to include data validation and prevent SQL injections / apply a password change (and strong password use) policy, and implement MFA.

I have strong analytical skills (problem-solving, critical thinking and creativity), which are essential for understanding critical vulnerabilities, seeing beyond the evidence, and using creativity to make effective decisions. Further, my methodical approach enables me to complete projects/tasks smoothly and timely.

I have good soft skills, such as Microsoft Office, Google Collaborative, Zoom, etc. allow me to communicate with the relevant team, stakeholders independently. Further, I have project management and compliance experience that will assist me in managing multiple teams, completing the given project complying with the rules and regulations for cybersecurity. Finally, I have long-term retail work experience, which will help me adapt to sudden change and work at a fast pace. In summary, my passion to learn about the recent cybersecurity trends, along with all the above knowledge and skills will enable me to do the job perfectly.

Tutor Comment: You provided clear examples of your technical skills, including Kali Linux, Python, SQL and data visualisation, which are highly relevant for cybersecurity roles. Including real examples of tasks you can perform (e.g. restoring ransomware backups, implementing password policies, preventing SQL injections) is extremely strong evidence of competence. Your analytical skills and methodical approach are clearly explained and match the needs of roles like SOC analyst, threat analyst or penetration tester. Soft skills such as communication, project management and working with stakeholders are well described and are crucial in cybersecurity.

You mentioned cloud as a gap: adding more detail about what aspects of cloud security you want to focus on (AWS IAM, networking, incident response) would be helpful. Your retail experience is a great asset; you could link it more directly to cybersecurity roles (e.g. fast-paced environments similar to incident response).

Overall, this is an excellent assessment with strong technical and practical examples and an impressive level of reflection and clarity.

2.4 Create a personal development plan.

You must create a personal development plan to address the areas for development identified within the personal skills analysis in 2.2 and assessment in 2.3; this must include SMART targets.

- [Template 1](#)
- [Template 2](#)

Tutor Comment: Thank you. Your Personal Development Plan goals are clear, relevant and directly support your skill gaps and future career direction. You included resources, deadlines and steps, which shows good organisation and planning. OSINT, pen testing, cloud and Security+ are all appropriate and industry-aligned learning paths. Adding cloud learning is a smart choice since you identified it as a weakness earlier.

Some goals could be broken down into more specific, actionable steps (e.g. "Complete TryHackMe OSINT rooms" or "Set up AWS free tier account"). Consider adding a column for progress tracking (e.g. "Not started," "In progress," "Completed") to demonstrate continuous development. For the apprenticeship goal, you could include preparatory steps such as updating CV, writing a personal statement or preparing for technical interviews.

Overall, you submitted a strong PDP that clearly connects to your SWOT and skills assessment.

Learning outcome 3: Understand the importance of continuous professional development

3.1 Explain the term continuous professional development (CPD)

The term 'Continuous Development Plan (CDP)' means all the actions and efforts taken by the professionals. CDP is basically a lifelong learning and updating process for working-class people. This helps them to learn recent trends and train them accordingly to enhance their knowledge and skills. Most of the companies require keeping a record of CPD activities.

Tutor Comment: Good account of Continuous Professional Development.

3.2 State methods of keeping up to date with industry knowledge

Continuous professional development is essential for cybersecurity professionals to keep them up-to-date with recent software, technology, or threats, for example. For this, they can take a mixed approach. Taking further courses in any specific area, subscribing to newsletters, connecting with other professionals, reading relevant research papers, blogs, watching videos, attending webinars and conferences, gaining certificates, practising on the Capture the Flag platform (Try Hack Me/Hack the Box), etc., are different ways of CPD.

Some other sources are:

- >industry publications and whitepapers
- >podcasts
- >the news (Dark Reading, Bleeping Computer, The Hacker News, etc.)
- >professional communities
- >following relevant professionals or groups on LinkedIn
- >the National Cyber Security website
- >TEDTalk conference
- >research about recent attacks and solutions
- >attend local events

So, we can see that there are many ways to learn and keep professionals up-to-date.

Tutor Comment: Great examples: listing multiple ways to keep up to date shows awareness of industry practice.

3.3 Explain why it is important to keep CPD up to date

Keeping CPD up-to-date is crucial for cybersecurity professionals. Technological inventions are soaring and cyber criminals are getting smart to smarter. On the other hand, the smartness of AI is spreading its nest for quick solutions. However, attackers are using it for negative purposes. So, cyber professionals' knowledge should be ahead of attackers' to protect all the information assets. They need to keep their knowledge up-to-date in new technologies, software, methods, and plans in all ways to fight against cyber criminals and keep the country safe both internally and externally. CDP will help professionals to remain competitive and add value to their organisations. The more knowledge and skills they have, the better defense they will take. CDP will not only benefit the organisation and country, but also help professionals to get promotions (senior roles, salary increase). Therefore, CPD is important to keep professionals up-to-date.

Tutor Comment: Good coverage of reasons why CPD is important in cybersecurity.

Conclusion

1. Where in this unit did you use AI to support your work?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Your answers appear original; the content of outcome 2 appears authentic and based on personal experience.

2. Which AI tool(s) did you use?

If not applicable to you, please answer "N/A"

Used Grammarly for spelling check.

Tutor Comment: Criteria met

3. On what date(s) did you use the AI tool(s)?

If not applicable to you, please answer "N/A"

N/A

Tutor Comment: Criteria met

I confirm that the evidence listed above and enclosed is my own work and was carried out under the conditions and context specified in the standards, as such no plagiarism was conducted during the completion of this portfolio.

TYPE YOUR NAME:

Rozina Khatun

Tutor Comment: Criteria met

DATE:

14/11/2025

Tutor Comment: Criteria met

Tutor Feedback

COMMENTS:

Tutor Comment: In this module you provided a detailed response that shows a good understanding of the key topics and you explained your ideas in a clear and structured way. Your work covers all required areas and you gave relevant examples to support your points, which strengthens your explanations.

You clearly explained why managing a positive digital identity is important and how platforms such as LinkedIn help with networking and job opportunities. You also showed good awareness of how employers use online information during recruitment. You covered a wide range of employee screening checks, including DBS, right-to-work, identity checks, credit checks and security checks. Your explanations show a solid general understanding of what these checks are for and why employers use them. You successfully identified several realistic consequences of unsatisfactory checks such as withdrawal of job offers, legal action for false information and reputational risks for both employers and candidates. Your descriptions of BPSS, SC and DV are clear and show awareness of the different requirements and renewal periods.

You identified a good range of biases such as gender, age, affinity, ethnic, educational and algorithmic and you explained how they can influence hiring decisions and team diversity, which demonstrates good insight. You highlighted key security by design principles such as Zero Trust, Least Privilege, MFA and encryption and you explain how these support secure working practices.

You provided a detailed list of technical, analytical and soft skills needed in cyber roles; you also correctly note the importance of legal awareness and leadership skills. You submitted a strong, highly detailed and professional SWOT well-linked to cybersecurity career requirements; your skills assessment is very strong with real examples and your PDP shows clear planning and motivation.

You correctly explained what CPD is, why it matters and the many ways professionals can stay up to date. You provided a wide variety of CPD methods, which shows good understanding.

Some sentences are long or unclear; shortening and proofreading would make your work more professional and easier to read. A few terms are used incorrectly (e.g. CPD stands for “Continuous Professional Development” instead of “Continuous Development Plan”; “biasness” should be “bias”). Checking terminology will improve accuracy.)

Overall, you showed good understanding and strong effort across all sections. Your explanations are relevant, you covered the required points well and you demonstrated awareness of key cybersecurity concepts and professional practices.

DATE:

Tutor Comment: 14/11/2025

I confirm that this student has achieved all the requirements of the units with the appropriate evidence/s enclosed. Assessment is valid, authentic, reliable, current and sufficient.

ASSESSOR FULL NAME:

Tutor Comment: Paola Palazzo

ASSESSOR SIGNATURE:

Tutor Comment: Paola

Conclusion

Assessor Comments (Assessor to complete)

I confirm that this student has achieved all the requirements of the units with the appropriate evidence/s enclosed. Assessment is valid, authentic, reliable, current and sufficient.

ASSESSOR FULL NAME:

Tutor Comment: Paola Palazzo

ASSESSOR SIGNATURE:

Tutor Comment: Paola

FEEDBACK TO STUDENT:

Tutor Comment: Across all six units you consistently demonstrated strong engagement, thorough research, practical and theoretical understanding and good awareness of legal, ethical and professional considerations.

Unit 1 provides strong, detailed understanding of cyber security fundamentals including the CIA triad, threats, vulnerabilities, actors, motivations and security by design. Excellent use of real-world examples (NHS, NotPetya) and clear links to Safeguarding, Equality and Diversity and British Values.

Unit 2 demonstrated strong knowledge of cyber threat intelligence, malware, OSINT, social engineering, threat models and the threat intelligence lifecycle. Excellent use of real-world examples (WannaCry, Jaguar Land Rover, M&S). Good integration of Safeguarding, Equality and Diversity and British Values.

Unit 3 showed good understanding of cybersecurity testing, vulnerabilities, mitigation controls and frameworks (NIST, CIA triad, NCSC). Strong practical examples and structured approaches to vulnerability response and reporting.

Unit 4 provided clear understanding of incident response plans (IRPs), post-mortems and frameworks (NIST 800-61, ISO 27035). Strong explanations of triggers, lifecycle stages, logging and post-incident analysis, with practical examples (JLR cyberattack). You demonstrated professional awareness and British Values.

Unit 5 showed strong grasp of UK and international cyber law, ISO standards and ethical considerations. Good use of real-world examples (Stuxnet, NotPetya, Sycamore Gap) and discussion of emerging trends (AI, quantum). Ethical behaviour and consequences of misconduct are well explained. Unit 6 demonstrated detailed understanding of professional practices, digital identity, pre-employment checks, vetting (BPSS, SC, DV), bias, security by design, skills and CPD. Strong examples, SWOT analysis, PDP and career-focused insights.

Overall, your key strengths include real-world examples, detailed explanations and integration of Safeguarding, Equality and Diversity and British Values.

Please click on the next section to conclude the course.

Declaration of Authenticity (Learner to complete)

I confirm that the evidence listed above and enclosed is my own work and was carried out under the conditions and context specified in the standards, as such no plagiarism was conducted during the completion of this portfolio.

TYPE YOUR NAME:

Rozina Khatun

Tutor Comment: Criteria met

DATE:

14/11/2025

Tutor Comment: Criteria met